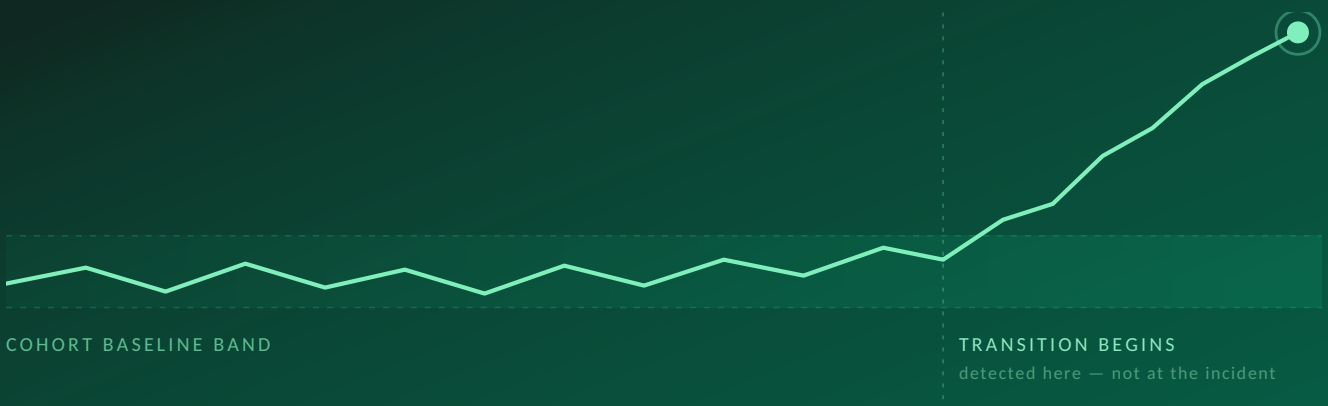
CYBERFORGE BY MITIGATA · AI & CYBERSECURITY

tellTale

Behavioural transition detection for identity threat and insider risk — context-aware, agentless, explainable.

> A telltale is the ribbon on a sail. It does not tell you the wind is blowing — you already know that. It tells you the airflow has **changed direction**, seconds before the sail stalls.
>
> Security tools alarm on events. **tellTale scores the change in direction.**



TEAM NAME	**Purple Crocs**
TRACK	**AI & Cybersecurity · CyberForge by Mitigata**
PROBLEM STATEMENT	**Detecting compromised and insider accounts before the incident**
SOLUTION TITLE	**tellTale**
TEAM MEMBERS	**Aarav Gupta · Aankhi Roy**

MASTER SOLUTION DOCUMENT · v1.1 · SOLUTION | TECHNICAL IMPLEMENTATION | FEASIBILITY | BUSINESS STRATEGY

DOCUMENT MAP

Contents & How To Read This

This document is the single source of truth for tellTale. It supersedes all earlier working drafts. It is organised into four parts that map directly onto the four things a reviewer needs to believe: that the idea is **right**, that it can be **built**, that it can be built **by us, in the time available**, and that it can be **sold**.

Part 1 — Solution

1.1 The silent shift, stated precisely
1.2 Why current tools miss it: three structural failures
1.3 Core thesis: score the transition, not the event
1.4 Scope boundary: what tellTale is and is not
1.5 Signal taxonomy: what we ingest, what we refuse
1.6 The five detection primitives
1.7 Context verification — and the attack on it
1.8 Three users, one identical command
1.9 The investigation dossier
1.10 Prioritisation and the investigation console
1.11 Innovation beyond the brief

Part 2 — Technical Implementation

2.1 System architecture
2.2 Data model and normalisation
2.3 Layer 1 — robust baselines and cold start
2.4 Layer 2 — trajectory modelling
2.5 Layer 3 — cohort divergence and slow burn
2.6 Layer 4 — context verification engine
2.7 Layer 5 — risk fusion and calibration
2.8 Explainability by construction
2.9 API surface and tech stack
2.10 Evaluation protocol (the honest version)
2.11 Adversarial robustness
2.12 Privacy architecture
2.13 What we deliberately did not build

Part 3 — Feasibility

3.1 Current status: what exists today
3.2 The 36-hour build plan
3.3 Portability to other detection problems
3.4 Team allocation
3.5 Real-world deployment feasibility
3.6 Performance and cost envelope
3.7 Inclusivity and fairness
3.8 Legal and regulatory feasibility, India in detail
3.9 Risk register and mitigations
3.10 Kill criteria

Part 4 — Business Strategy

4.1 Category and buying reality
4.2 Ideal customer profile
4.3 Competitive landscape
4.4 Pricing and packaging
4.5 Unit economics
4.6 Market sizing with derivation
4.7 Go-to-market: the 15-minute audit wedge
4.8 Marketing and media strategy
4.9 Scalability and sustainability
4.10 Defensibility
4.11 24-month roadmap
4.12 The non-human identity expansion
4.13 What would have to be true

Appendices

A Corrections register — what we changed and why
B Glossary in plain English
C Evaluation results template
D Evidence base and sourcing discipline

ON THE INTEGRITY OF THE NUMBERS IN THIS DOCUMENT

Every quantitative claim here carries one of three labels, and we hold to them throughout. **Measured** means we produced the number from our own instrumented runs and can reproduce it on demand. **Derived** means we computed it from stated assumptions that are written down and can be challenged. **Estimated** means it comes from public secondary sources we have not independently verified.

We have removed several confident-sounding metrics that appeared in our earlier research drafts because they were none of the three — most notably a claimed detection accuracy figure on a public dataset we had not actually run against. Section 2.10 explains what we replaced it with. We would rather present a smaller number we can defend than a larger one we cannot.

*Context: prepared for **CyberForge by Mitigata**, theme AI & Cybersecurity. The problem statement is our own, drawn from the brief's suggested areas of threat detection, AI-assisted security operations, fraud and account takeover, and AI security. Earlier drafts of this work were written for a different competition; this version replaces those references.*

At a glance

Question	Answer
The problem	A compromised or malicious account behaves normally, then shifts. Every individual action is authorised. The signal is in the sequence and the direction of travel, not in any one event.
Why it is unsolved	Deployed tools threshold single events (blind to sequence), have no access to why an action happened (blind to context), and emit a bare score an analyst cannot act on within their real time budget.
Our thesis	Score the *transition*, then verify it against the organisation's own records — the ticket, the on-call rotation, the employment status — before it ever reaches a human.
How it works	Five independent detectors: robust volumetric baselines, Markov trajectory surprisal, anchored cohort divergence, communication-graph topology, and honeytokens. Fused by a calibrated logistic model whose per-feature contributions *are* the explanation.
What is novel	Context gating treated as an attack surface — four-test verification plus a detector for the manufacturing attempt itself. Anchored references that a slow-burn attacker cannot poison. Queueing designed against the analyst's actual daily capacity.
What it refuses	No keystroke or mouse biometrics, no screen recording, no message or file content, no endpoint agent. Metadata only, pseudonymous by default, dual-custody unmasking.
Build	Python 3.12 · FastAPI · PostgreSQL 16 · NumPy/SciPy · Next.js 16 · Docker Compose. No GPU, no deep learning, runs entirely offline on one laptop.
Commercial shape	India-first, sold into an existing workforce-analytics budget and an underused ITDR budget at once. ₹6,000 per identity per year blended, ~76% gross margin, entered through a free 15-minute retrospective audit that produces findings on day two.
Honest limits	Weak against small, targeted theft strictly inside a user's legitimate scope. Dependent on the customer actually using their ticketing system. Evaluation numbers are pending a run we have not padded in advance (§2.10, Appendix C).

PART ONE

Solution

1.1 The silent shift, stated precisely

An account does not usually announce that it has turned hostile. The compromise or the decision to steal happens first, and the observable behaviour changes afterwards — gradually, in steps each of which is individually permitted. The engineer who will exfiltrate the payments repository on Friday spent Monday doing exactly what an engineer does. On Tuesday they read a runbook they had no reason to read. On Wednesday they cloned a repository outside their team's scope. On Thursday they generated a personal access token. Each of those four actions is authorised. Each is, on its own, unremarkable. The fifth action is the incident.

Our problem statement calls this the silent shift, and the phrasing is exact. There is no single moment where behaviour becomes malicious. There is a **trajectory** — a direction of travel — and the job of a detection system is to notice the direction changing while there is still time to intervene.

Two properties of this problem make it genuinely hard, and they pull against each other:

- **The signal is distributed across events, not concentrated in one.** Any detector that scores individual actions in isolation has thrown away the information that mattered before it started.
- **Legitimate behaviour changes constantly, and for the same reasons.** A promotion, a team transfer, a production incident at 2am, a new project, a contractor onboarding onto an unfamiliar codebase — all of these produce exactly the shape of deviation that theft produces. An organisation of 2,000 people generates dozens of genuine behavioural transitions every week.

This is why the naive approach fails so comprehensively. Sensitivity to transitions and tolerance for legitimate change are in direct tension. Turn the detector up and you drown the analyst; turn it down and you miss the thing you built it for. Resolving that tension is the entire product.

1.2 Why current tools miss it: three structural failures

The market is not empty. Microsoft Purview Insider Risk Management, Exabeam, Securonix, Varonis, Proofpoint ITM and DTEX all claim behavioural analytics. The relevant question is not whether tools exist but why practitioners consistently report abandoning or muting them. Across vendor documentation, analyst coverage and practitioner discussion, three failures recur, and they are architectural rather than incidental.

Failure 1 — Point-in-time thresholding

Most deployed detection reduces to: compute a rolling mean and standard deviation per user per metric, alert when today exceeds $\mu + k\sigma$. This is a snapshot comparison. It cannot express "downloading is fine, and archiving is fine, and uploading is fine, but doing all three in this order within forty minutes is not." Sequence is the carrier of intent, and thresholds are blind to sequence.

Worse, rolling windows are self-poisoning. An attacker who takes five files a night for sixty days never exceeds the threshold on any single day, and by day thirty the elevated rate *is* the baseline. The attack teaches the detector to accept it. This is not a tuning problem; it is a property of using a moving average as a reference.

Failure 2 — Context blindness

Security telemetry and operational reality live in separate systems that do not speak. The detection engine knows that user 4912 cloned a repository at 01:22. It does not know that a ticket assigning that repository to user 4912 was created yesterday by their team lead. That fact exists, in Jira, one API call away — and it is the single most decision-relevant piece of information available. Legacy platforms were architected around log ingestion pipelines (syslog, Windows Event Forwarding, CEF) and inherit a worldview in which the only data that matters is data that arrives as a log line. Human resources status, ticket assignment, on-call rotation, and calendar are not logs, so they are not ingested.

The consequence is that the most common cause of anomalous behaviour in any enterprise — somebody's job changed — is invisible to the system whose job is to interpret anomalous behaviour.

Failure 3 — The explainability deficit

The output of most of these systems is a scalar. `Risk: 87`. An analyst receiving that number cannot act on it. They must pivot across identity logs, endpoint telemetry, cloud audit trails and email gateways to reconstruct what happened, and only then decide whether it mattered. Practitioner accounts put this reconstruction at two to four hours per alert. At a realistic alert volume this is arithmetically impossible, so the alerts are not investigated. A detection system whose output cannot be acted on within the analyst's actual time budget has not detected anything.

> **THE COMPOUNDING EFFECT**
>
> These three failures multiply rather than add. Point-in-time thresholding generates volume. Context blindness ensures most of that volume is legitimate business activity. The explainability deficit makes each item expensive to dismiss. The end state is a team that has a behavioural analytics platform, pays for it, and routes its alerts to a channel nobody reads. Every subsequent design decision in tellTale is aimed at one of these three.

1.3 Core thesis: score the transition, not the event

tellTale replaces the unit of analysis. The thing we score is not an event. It is a **transition**: a directional change in an identity's behaviour, evaluated over a window, against what that identity used to do and what comparable identities are doing now, and then checked against whether the organisation actually asked for it.

Concretely, a risk assessment in tellTale answers five questions in order:

> **1. Is the volume different?** Robust per-user baselines using median and median absolute deviation, which do not get dragged around by a single busy day.

▼

> **2. Is the *path* improbable?** The sequence of actions scored against empirical transition probabilities — how often, across this organisation, does action C follow B follow A?

▼

> **3. Is this person drifting away from their peers?** Cohort divergence against a fixed historical anchor, which is what catches the slow burn that a rolling window cannot.

▼

> **4. Did the organisation ask for this?** Scope-verified context: a ticket that authorises *this specific resource*, assigned by someone else, before the activity began.

▼

> **5. How does this rank against everything else on the analyst's desk today?** Calibrated probability, not an arbitrary score, so that ranking is meaningful.

The fourth question is the one no incumbent asks properly, and it is where most of the false-positive reduction comes from. The fifth is the one that determines whether the system is used at all.

> **WHY THE NAME**
>
> A telltale is a short ribbon attached to a sail. Sailors do not watch it to learn that there is wind. They watch it because when the airflow begins to separate from the sail, the ribbon flutters *before* the boat loses drive. It is a small, cheap, early indicator of a change in direction. The word also carries its ordinary English meaning — the small sign that gives something away. Both readings describe the product, which is the test of a good name.

1.4 Scope boundary: what tellTale is and is not

Being explicit about the boundary is a feasibility statement as much as a design one. A system that claims to detect everything detects nothing on a schedule.

tellTale is	tellTale is not
A detection and investigation layer over cloud identity and SaaS audit APIs.	A log warehouse or SIEM replacement. We consume audit events; we do not aspire to store everything.
A prioritisation engine that produces a ranked, evidence-backed queue for a human investigator.	An autonomous enforcement system. A human approves every consequential action in v1.
Metadata-first across cloud APIs and, where the Sensor is deployed, the endpoint.	A content inspection or DLP engine. We never read file contents, message bodies, source code or keystrokes. Screen capture, where enabled, is the single exception and is governed separately (§1.5.1).
Agentless by default, with an optional endpoint Sensor for organisations that need visibility into local and non-API activity.	A kernel-level surveillance tool. The Sensor runs in user space, records no keystrokes, and installs no drivers.
An account-scoped behavioural model, applied identically to humans, service accounts and AI agents.	A judgement about people. tellTale scores the behaviour of a credential, not the character of an employee.

That last row is not a legal disclaimer, it is a design constraint that changes the product. Because the unit of analysis is the credential rather than the person, the same engine works unmodified on non-human identities (§4.12), and the pseudonymisation architecture (§2.12) costs us nothing — we were never modelling the person in the first place.

1.5 Signal taxonomy: what we ingest, and what we refuse

An early version of this concept included keystroke dynamics, mouse movement biometrics, device accelerometer telemetry and continuous screen recording. We removed all of them. The reasoning is worth recording, because "we considered this and rejected it for these reasons" is a stronger position than never having considered it.

Signal	Verdict	Reasoning
Identity events — authentication, MFA outcome, session lifecycle, ASN and geo, token issuance	CORE	Highest-value, lowest-noise signal available. Session theft is the dominant modern attack and it is visible here and almost nowhere else.
SaaS and developer audit events — repository clone, archive creation, permission change, external share, bulk export, IAM policy edit	CORE	These are the actions that constitute the attack. Available via audit APIs with no agent.
Operational context — ticket assignment, on-call rotation, employment lifecycle, calendar, travel	CORE	The differentiator. Converts an anomaly into a verdict. See §1.7.
Communication graph *metadata* — who messages whom, channel joins, external-domain edges, attachment counts	CORE	Topology change is an early indicator of collusion and of pre-departure hoarding. Requires no access to message content.
Honeytokens — decoy credentials and documents seeded in plausible locations	ADDED	A deterministic signal with essentially no false-positive rate: there is no legitimate reason to touch a decoy. Cuts through model ambiguity and works from day one with no baseline.
Application and window metadata — process, window title, resource identifier, duration, category	CORE · SENSOR	The endpoint equivalent of an audit log line, and the fix for the largest blind spot in an API-only design: local files, internal tools and legacy applications that expose no audit API at all. These become additional trajectory tokens, so the detection engine consumes them without modification.

Presence and idle state — active, idle, locked, offline	CORE · SENSOR	Cheap to collect and more valuable than it looks. Identity activity occurring while the endpoint reports the user idle, locked or offline is a strong session-theft and credential-sharing indicator (§2.5.1). It also sharpens the per-person working-hours envelope used in §3.7.
Screen capture — scheduled and triggered	TIERED · PROFILE-GATED	Lawful on corporate hardware across our market. Scheduled capture supports the workforce module; triggered capture supplies forensic corroboration during an investigation. This is the one place we collect content, so it is governed by the jurisdiction profiles in §3.8 rather than left to a toggle.
Keystroke logging — recording typed text	REJECTED	Content surveillance with a poor security return. We record that a document was opened and by whom, never what was written in it. This is the line that keeps the Sensor defensible in works-council negotiation and in the narrow reading of India's s.7(i).
Keystroke and mouse dynamics — cadence as identity	REJECTED	Intra-person variance swamps between-person variance — cadence shifts with fatigue, hardware, and network jitter on remote sessions. Under GDPR it is biometric data (Art. 9) where used to identify a person. India's DPDP Act has no special-category regime at all, so there the objection is signal quality, not law.
Device accelerometer / gyroscope	REJECTED	Enterprise work happens on stationary hardware. There is no theory under which laptop movement predicts data theft.
Screen capture and continuous screen recording	NOT BY DEFAULT	Lawful on corporate hardware across most of our market, and India's DPDP s.7(i) arguably supports it outright. We decline it by default for architectural reasons, not legal ones — see below. Retained as an optional triggered module (§4.11).
Email and chat body text analysis	REJECTED	Confidentiality liability outweighs signal. We take the graph, not the text.

1.5.1 The Sensor and screen capture: how we use them

On company-owned devices with notice, endpoint collection including screen capture is lawful across our target market: the United States by policy and consent, Germany under a negotiated works agreement (BetrVG s.87(1) No. 6 confers co-determination — a negotiation, not a veto), and India inside a statutory provision that names trade-secret protection and espionage prevention outright. We ship it.

What we do not do is let it become the primary detector, and the reasons are worth stating because they determine how the feature is built:

Reason	Detail
Deployment cost is real	The Sensor means MDM rollout, three operating systems, update cycles and support burden. Time to first finding goes from fifteen minutes to days. So the cloud plane ships first and alone: we land agentless, prove value in 48 hours, and expand to the Sensor once the customer already believes us (§4.7).
Pixels do not feed the engine	Our detection is sequence surprisal over a controlled action alphabet. A screenshot has no position in a Markov chain. Extracting anything requires OCR or a vision model — costly, noisy, and unexplainable, which breaks the one property the product is sold on.
It breaks the cost model	We carry roughly 350 bytes per event. One capture every 30 seconds is several gigabytes per user per month — two to three orders of magnitude more storage, taking the margin and the price point with it.
It misses part of the threat model	Session-token abuse, CLI and webhook exfiltration are frequently headless — nothing appears on screen. Capture corroborates an investigation; it cannot be the thing that raises the alarm, or the headless attacks go unseen.
A capture is identifying	The mail client in the corner carries the person's name. So captures are stored encrypted, excluded from the analyst's default view, and released into a dossier only under the same dual-custody approval that governs unmasking (§2.12). The pseudonymisation architecture stays real rather than decorative.

Two capture modes, deliberately separated

Mode	Behaviour	Purpose and governance

Scheduled	Fixed interval during active sessions, configurable cadence, default five minutes. Off outside working hours. Exclusion lists per application and per URL pattern.	Powers the workforce module (§1.10.2). Enabled by default in the India and US profiles, disabled by default in the EU profile, and available in Germany only under a works agreement (§3.8).
Triggered	A bounded window around a high-confidence event — a honeytoken touch, or a calibrated score crossing a configured threshold. Dormant otherwise.	Forensic corroboration inside an investigation dossier. Available in every profile, because a system that is dormant until behaviour justifies it survives the proportionality test that continuous capture struggles with.

Keeping these separate is what lets one product serve a customer who wants full workforce visibility and a customer whose works council will permit nothing but incident forensics, without shipping two products or asking either to accept the other's posture.

> **THE REFUSALS ARE A FEATURE, NOT A COMPROMISE**
>
> Every rejected signal is one an invasive competitor does collect. That asymmetry is the basis of a commercial position, not just an ethical one: tellTale can be deployed in jurisdictions and organisations where those competitors are legally or politically blocked. §3.8 develops this. The design principle we hold to is simple — **collect the minimum metadata sufficient to reconstruct a trajectory, and nothing that describes the person rather than the action.**

1.6 The seven detection primitives

tellTale composes seven independent detectors. Independence matters: each has a different failure mode, so an evader who defeats one is unlikely to have defeated the rest, and corroboration across primitives is what distinguishes a real finding from noise. The mathematics is in Part 2; here is what each one is *for*.

Primitive	What it catches	What it cannot catch
Volumetric deviation *median/MAD, robust*	Sudden bulk activity: mass download, mass export, mass permission change. The loud version of the attack.	Anything low and slow. Anything where volume is normal but composition is not.
Trajectory surprisal *Markov, order-2 with backoff*	Improbable *paths* through authorised actions — the living-off-the-land pattern where every step is permitted and only the order betrays intent.	Attacks that use common transitions in a common order but against the wrong resource.
Cohort divergence *anchored, not rolling*	Slow burn. Drift away from the peer group over weeks, measured against a frozen historical anchor so the attack cannot poison its own reference.	Fast attacks that complete inside one evaluation window. Cases where the whole cohort shifts together.
Graph topology change *metadata edges only*	New cross-department edges, sudden external-domain communication, isolation from a former team — early indicators of collusion and pre-departure behaviour.	Solo actors who do not communicate. Anything inside an existing edge.
Presence divergence *Sensor only*	Identity activity occurring while the endpoint reports the user idle, locked or offline. Session theft, shared credentials, and automation running under a human's name.	An attacker operating at their own desk during their own working hours.
Composition drift *Sensor only*	A sustained shift in the mix of application categories a person works in, measured against their own anchor and their cohort — the engineer whose day quietly becomes browsing and file management.	Attacks carried out inside an entirely normal application mix.

Deception triggers *honeytokens*	Any access to a decoy resource. Near-deterministic, needs no baseline, works on day one and against brand-new accounts.	Attackers who never encounter a decoy. Coverage is a placement problem, not a detection problem.

No single primitive is novel in isolation, and we do not claim otherwise. The contribution is the composition, the context layer that arbitrates between them, and the fact that the whole thing is inspectable end to end. The last two require the Sensor; the first five run on cloud telemetry alone, which is why an agentless deployment is still a complete product rather than a crippled one.

1.7 Context verification — and the attack on it

Context gating is the mechanism by which an anomalous-looking action is checked against whether the organisation asked for it. A naive implementation looks like this:

```
if user has an open Jira ticket → multiply risk by 0.15
```

This is exploitable, and our earlier design had exactly this hole. An insider who knows the rule simply creates a ticket. The control that was supposed to suppress false positives becomes a self-service mechanism for suppressing true ones. Any competitor who ships naive context gating has built an evasion primitive and shipped it to the adversary.

We hardened it. Context only earns suppression when it satisfies four independent tests, and the provenance of the context matters as much as its existence:

Test	Requirement	What it defeats
Precedence	The context record must have been created *before* the activity it authorises, by a margin exceeding a configured minimum (default 30 minutes).	Retroactive justification — filing the ticket after the download to launder it.
Provenance	The assignment must originate from an identity other than the subject. Self-assigned work carries materially reduced weight; self-assigned work on a resource outside the subject's historical scope carries *none*.	The insider who creates and assigns their own authorisation.
Scope match	The context must reference the specific resource touched — this repository, this database, this bucket — resolved through a resource map, not merely be "an open ticket".	Using an unrelated open ticket as blanket cover for any activity.
Proportionality	The volume and breadth of activity must be plausible for the scope of work described. A ticket scoped to one service does not authorise cloning forty repositories.	Legitimate small mandate used as cover for a large action.

The manufactured-context detector

Hardening the gate is defensive. We also made the attempt itself a detection signal, which is the part we think is genuinely novel. **Context manufacturing is anomalous behaviour in its own right and can be modelled with the same machinery as anything else.**

An employee who self-assigns a ticket referencing a repository they have never contributed to, and clones it forty minutes later, has produced a distinctive and highly improbable trajectory: `ticket.create(self) → ticket.assign(self) → first-ever access(scope)`. We score that path like any other. Empirically, in an organisation with functioning process, it is rare — which is precisely what makes it detectable.

> **DESIGN PRINCIPLE: NO SUPPRESSION CHANNEL WITHOUT A CORRESPONDING DETECTOR**
>
> Any mechanism that can lower a risk score is an attack surface. For each such mechanism, tellTale ships a paired detector that fires when the mechanism is being exercised abnormally. Context gating has the manufactured-context detector. Baseline learning has cohort divergence. Connector health has dead-man heartbeats (§2.11). We treat this as a standing architectural rule rather than a one-off fix.

1.8 Three users, one identical command

The clearest demonstration of the thesis is to hold the technical action constant and vary only the context. All three of these users execute `git clone git@github.com:corp/payments-core.git`, a repository none of them has ever touched. A conventional tool sees one event type, three times, and must treat them identically.

	Priya — legitimate	Marcus — compromised	Dana — manufactured context
Trajectory	Corporate network → SSO → clone → branch → pull request opened	Login from unfamiliar ASN (commercial VPN, Zurich) → clone → tar archive → upload to unaffiliated S3 bucket	Corporate network → creates ticket → self-assigns it → clone → archive → personal cloud sync
Volumetric	**Within baseline**	**Z ≈ +12 on archive size**	**Modestly elevated; individually unremarkable**
Trajectory surprisal	**Common path (clone→PR is the modal developer sequence)**	**P(external upload | archive) ≈ 0.0004 in this org**	**Self-assign→first-access path is rare**
Cohort divergence	**Tracking peers**	**Sharp break from anchor**	**Gradual 6-week drift, +260% vs cohort**
Context: precedence	**Ticket created 1 day prior**	**No ticket at all**	**Created 40 min prior — passes**
Context: provenance	**Assigned by team lead**	**n/a**	**Self-assigned → weight withdrawn**
Context: scope	**Ticket names this repository**	**n/a**	**Names it, but subject has no contribution history**
Employment signal	**Active, no change**	**Resignation filed 4 days ago**	**Active — no HR signal available**
tellTale verdict	**14 / 100 — suppressed** **Never reaches a human**	**93 / 100 — critical** **Top of queue, dossier in seconds**	**78 / 100 — high** **Flagged on manufactured context + drift**
Legacy tool verdict	**Severity 1 — false positive, ~45 min of analyst time**	**Three uncorrelated alerts in three consoles, none conclusive**	**Silent — ticket present, volume under threshold**

Dana is the case that matters most, and it is the one absent from every competitor demo we reviewed — including our own earlier drafts. Priya versus Marcus demonstrates context suppression, which is a good story but a solved one. Dana demonstrates that we thought about what happens when the adversary knows how the system works. That is the difference between a demo and a design.

1.9 The investigation dossier

Detection that an analyst cannot act on is not detection. tellTale's output is never a bare score; it is a structured dossier assembled from the same evidence the model used, with each contributing factor and its weight shown explicitly. Nothing in it is generated text describing what the model "thinks" — every line is a rendered fact with a pointer back to the underlying event.

```
═══════════════════════════════════════════════════════════════════
INCIDENT TT-2026-09-0412          SUBJECT #4912 (pseudonymous)   STATUS CRITICAL
CALIBRATED RISK 93 / 100            COHORT  Backend Engineering (n=34)
═══════════════════════════════════════════════════════════════════

WHAT HAPPENED
  Four-step exfiltration trajectory across 3 platforms in a 28-minute window,
  with no operational context authorising any part of it.

  01:14  okta.session.start      New ASN · commercial VPN · Zurich   first in 180d
  01:18  okta.mfa.challenge      Push approved — consistent with session theft
  01:22  github.repo.clone       payments-core                       first ever
  01:35  github.archive.create   bundle.tar.gz · 410 files
  01:42  aws.s3.put_object       External bucket, outside org accounts first ever

WHY IT SCORED                                          contribution to logit
  Trajectory surprisal   P(s3.put | archive.create) = 0.0004    +3.10
  Employment signal      Resignation filed 4d ago (Workday)     +2.40
  Novel egress path      External bucket, no prior instance     +1.85
  Volumetric             410 files vs cohort median 12 (MAD 4)  +1.40
  Geo / ASN novelty      Unseen ASN, impossible travel 4.1h     +0.95
  Context verification   NO authorising record found            +0.00
                                                                ──────
                                        calibrated P(malicious) = 0.93

CONTEXT CHECKS RUN
  [FAIL] Ticket system     no open or historical ticket for payments-core
  [FAIL] On-call rotation  not on rotation at 01:14 UTC
  [FLAG] Employment        voluntary resignation, effective in 10 days
  [FAIL] Travel / calendar no approved travel; last known location Bengaluru

COMPARABLE PRECEDENT
  17 cohort members cloned a new repository in the last 90 days.
  17 of 17 had an authorising ticket. 0 of 17 uploaded outside org accounts.

RECOMMENDED ACTIONS                                    requires approval
  [1] Revoke active sessions across IdP and downstream apps
  [2] Suspend personal access tokens for this identity
  [3] Preserve audit trail for the 7-day window (immutable snapshot)
  [4] Request dual-custody unmasking — CISO + Legal, if escalating
```

Three properties of this artefact are deliberate. **The subject is pseudonymous** — the analyst investigates behaviour, not a named colleague, until an unmasking is independently authorised. **Contributions are additive and sum to the score**, so "why 93?" has an arithmetic answer rather than a narrative one. **Comparable precedent is included** — the cohort denominator is what turns "unusual" into "unprecedented", and it is the fastest way for an analyst to calibrate their own judgement.

On generated language: we use a language model for one thing only — smoothing the single "what happened" summary sentence into natural prose, with the deterministic template retained as fallback. It never touches a timestamp, a score, a probability or a factual claim. A hallucinated detail in this artefact would destroy the one property the product is sold on.

1.10 Prioritisation and the review console

Our problem statement asks the system to "prioritise activity for human investigation", and this is frequently treated as an afterthought — sort descending by score, done. It deserves more, because the binding constraint in every security team we are designing for is not detection capability but analyst hours. A lean mid-market team has perhaps two people who can triage, and realistically four to six hours of triage capacity per day between them.

tellTale therefore treats the queue as a budgeted resource rather than a sorted list:

- **Rank by priority score, not by raw risk.** Calibrated probability multiplied by an asset-criticality weight. A subject at 0.55 on production credentials outranks one at 0.80 on a marketing folder, and it should — this is the inversion an analyst notices in the first minute of using the console.
- **Aggregate to the identity, not the event.** One identity generating six related signals is one case, presented once, not six queue entries. This alone collapses volume substantially.
- **Explicit capacity awareness.** The console is configured with the team's daily triage budget and shows what fits inside it. Everything below the line is retained, visible and searchable — but it is not pretending to be actionable.

- **Feedback that costs one click.** Every dismissal records a reason code. Those become both a tuning signal and the evidence base for the quarterly review of whether the system is earning its place.
- **Suppressions are logged, not discarded.** When context suppresses an alert, the suppression is written to an auditable record with the reason. If the context turns out to have been manufactured, the trail exists. This is also what makes the false-positive-reduction claim auditable rather than rhetorical.

NAMING THE CONSOLE IN PLAIN ENGLISH

The engineering terms in Part 2 are precise but not how an analyst talks. The shipped console renames every surface into the language a triage shift actually uses, and this document uses the shipped names from here on:

Engineering term	Console label
Investigation queue	**Review alerts**
Expected cost of inaction	**Priority score** (risk × asset criticality)
Top contributing detector	**Trigger signal**
Connector heartbeat	**App connections**
Suppression log	**Approved activity**
Org summary (workforce)	**Team overview**
Application usage (workforce)	**App usage**
Attack path graph	**Action path**

1.10.1 Review Alerts and the security surfaces

We studied a production workforce-analytics platform in detail — a commercial product in that space — and took its information architecture while deliberately discarding its semantics. That distinction is the whole point, so we state it plainly rather than quietly borrowing. Its investigation surfaces were better than what we had originally specified; its productivity model is the thing tellTale's security module exists to avoid, and is kept firmly on the other side of the wall built in §1.10.2.

Surface	What it does in tellTale	Where the pattern came from
Composite timeline	Four lanes on one shared hour axis: session and authentication, action trajectory, context records in force, and risk over time. The analyst sees the shape of a day in one glance and can spot the moment the lanes stop agreeing with each other.	Adapted from a summary view that stacks activity, capture counts and application usage on a single axis. Strongest idea we found; our earlier dossier spec was weaker for lacking it.
App connections	Per-source online and offline instances with expected-volume bands, plus a continuous ribbon across the day. Gives the telemetry-starvation defence in §2.11 an actual screen — silence becomes visible rather than merely logged.	Adapted directly from a heartbeat instance table and summary ribbon.
Evidence flags	Tag and flag affordances on every item, each carrying a mandatory reason code that feeds both tuning and the quarterly review.	Adapted from per-item tag and flag controls on captured evidence.
Cohort filter triple	Group, then member, then date range — the universal filter across every view, with cohort meaning peer group rather than reporting line.	Adopted wholesale. It is the right default and needs no improvement.

Priority score breakdown	Risk apportioned by resource category and by detector, so an analyst can see whether a score is driven by one loud signal or by several quiet ones agreeing.	Structurally the same as a category donut — but measuring risk contribution, never productivity.
Evidence export	Immutable evidence packs for a subject and window, hashed and timestamped for legal or HR escalation.	Adapted from a daily-data download centre.

1.10.2 The workforce module

Where the Sensor is deployed, the same telemetry supports a second, entirely separate surface set: named, operational workforce reporting. This is what an operations or HR-systems owner expects to see, and in the Indian mid-market it is frequently the budget that already exists (§4.1). It ships as four screens.

Screen	What it shows
Team overview	Named employees across departments — Engineering, Infrastructure, Product, Finance, Operations — each row showing active versus idle hours for the day, a 24-hour activity ribbon, Sensor deployment status (equipped or unequipped), and their top application. Instant search by member name, team or top application, with sort by roster order, member name, team, or top application.
App usage	Time spent per application (Chrome, VS Code, Slack, Figma, iTerm2, Workday, Finder, and the rest of the fleet's software) rolled up into six functional categories — development, communication, browser, file management, administrative, other — shown as a live category donut plus a searchable, sortable table with a category filter.
Screen captures	A gallery of captures in the two modes from §1.5.1 — scheduled, at a five-minute cadence during active hours and automatically suspended outside them and on the exclusion list, and triggered, bounded to a window around a high-confidence security event. Sub-second search by member, application, capture ID or review flag; sort by newest, oldest, member or application. Each capture opens a full inspection view showing timestamp, process, window title and its current review state. Review flags: `Policy Review` , `Data Handling` , `Case Evidence` , `Miscapture` .
Member profile	The deep-dive on one employee's operational day — working versus idle breakdown, hourly activity ribbons, application distribution, and their capture trail in one place. The workforce equivalent of the investigation view, and just as deliberately named differently: this is a *profile*, not a *dossier*.

We ship all four, and we keep them structurally separate from the risk engine. That separation is not a setting; it is three invariants enforced in the product.

THE THREE GOVERNANCE INVARIANTS

Rule 1 — Productivity classification never enters a risk score. Application category *composition* is fed to the trajectory model as behavioural data (§1.6, §2.5.1) — a shift in what someone works on is a real signal. The subjective `productive / neutral / unproductive` label attached to a category is a management judgement with no causal path to data theft, and it is excluded from every risk calculation at the feature-extraction boundary. The model is never given the column.

Rule 2 — Complete separation of access roles. A Workforce Admin sees named employees, timesheets and usage, with zero access to risk scores or dossiers. A Security Analyst sees pseudonymous identities like `#4912` and threat trajectories, with zero access to productivity ratings. Holding both roles at once is possible only for a small, named set of accounts, and every session that does is logged.

Rule 3 — Risk investigations stay pseudonymous. The security module is anonymous by default. Bridging from a pseudonymous alert to a named identity is never a link in the interface — it is the two-person dual-custody unmasking workflow from §2.12, requiring independent approval from the CISO and Legal or HR before a name is revealed.

WHY THE SEPARATION, STATED PLAINLY

A product that can both measure someone's output and accuse them of theft is one configuration change away from doing the second because of the first. That is a real failure mode, it is the specific harm regulators and works councils are worried about, and it is not prevented by good intentions.

Our answer is architectural: the productivity classification is not an input the risk model can read, the two surfaces have separate role grants, and every crossing between them is an audited event. We would rather carry the engineering cost of that separation than defend its absence.

WHAT WE STILL DELIBERATELY DO NOT COLLECT

Keystroke content, message and email bodies, file contents, source code, and keystroke or mouse biometrics. These stay out permanently. The first four are content surveillance with a poor security return — we record that a document was opened, never what it said. The last is a weak signal that would additionally pull us into GDPR Art. 9, which is a disproportionate cost for a detector that does not work well.

That line — **metadata and imagery of the workspace, never the text a person produces** — is what keeps the Sensor defensible in a works-council negotiation and inside the narrow, security-specific reading of India's s.7(i) discussed in §3.8.1.

1.11 Innovation beyond the brief

Our problem statement asks for baselines, deviation detection, correlation over time, context handling and prioritised explanation. Those are the table stakes and they are all present. The following go beyond what was asked, and they are where we would direct a reviewer's attention.

Contribution	Why it matters
Adversarial context integrity *§1.7, §2.6*	Everyone proposes context gating. To our knowledge nobody treats the gate as an attack surface. The four-test verification plus a detector for the manufacturing attempt itself turns the most obvious weakness of the approach into a distinct capability.
Anchored cohort divergence *§2.5*	Rolling baselines are structurally defeated by slow-burn attacks. Scoring against a frozen anchor window plus peer-relative drift makes baseline poisoning ineffective — the reference cannot be moved by the subject.
Additive, auditable explanation *§2.8*	Because fusion is a logistic model over interpretable features, per-feature contributions are exact and free — no post-hoc approximation layer. The explanation *is* the model, not a story about it.
Capacity-aware queueing *§1.10*	Designed against the analyst's real time budget rather than an idealised one. Determines whether the system survives contact with a real SOC.
Identity-class agnosticism *§4.12*	Because we model credentials rather than people, service accounts and autonomous AI agents run on the same engine with no modification. This is the largest expansion vector available and it required no architectural concession.
Falsifiable evaluation *§2.10*	A protocol with blind scenario authoring, a held-out attack family, and a naive-detector control — designed so that our own numbers can prove us wrong.

PART TWO

Technical Implementation

This part specifies the system precisely enough to be built from, and states the mathematics rather than gesturing at it. A guiding constraint throughout: every intermediate quantity must be inspectable. We use no method whose output we could not explain to an analyst on a whiteboard, and we accept a modest accuracy cost to hold that line.

2.1 System architecture

tellTale is a batch-and-stream pipeline over audit APIs. There are no agents, no endpoints, no kernel modules, and no inbound network requirements at the customer.

1 · Collection. *Cloud plane:* read-only OAuth against identity (Okta / Entra), collaboration (Google Workspace), development (GitHub Enterprise), infrastructure (AWS CloudTrail) and context sources (Jira, HR system, PagerDuty), by webhook push where available and cursor polling where not. *Endpoint plane (optional Sensor):* a user-space agent reporting application and window metadata, process execution, file operations, device events, presence state, and — where the jurisdiction profile permits — screen captures. The Sensor buffers locally when offline and backfills on reconnect.

▼

2 · Normalisation. Every event is mapped to a single canonical schema aligned to OCSF class semantics, validated by Pydantic at the boundary. Unmapped fields are retained in a JSONB sidecar so nothing is lost, but the detection layer only ever sees the canonical form. Identifiers are pseudonymised here, before persistence.

▼

3 · Enrichment. Each event is joined to the identity's current role, cohort, employment status, asset criticality for the touched resource, and the set of active context records applicable at that timestamp. Enrichment is point-in-time — we record what was true then, not what is true now, so that replays are faithful.

▼

4 · Sessionisation. Events are grouped into behavioural sessions per identity using an idle-gap rule with a hard cap, producing the ordered action sequences the trajectory model consumes.

▼

5 · Detection. The five primitives run independently over the session and its enclosing windows, each emitting a bounded sub-score plus the evidence that produced it.

▼

6 · Context verification. The four-test gate (§2.6) resolves whether the organisation authorised this activity, emitting a signed multiplier and an auditable suppression record.

▼

7 · Fusion and calibration. Sub-scores and context terms combine through a fitted logistic model; the output is passed through a calibration map so the number is a probability rather than a vibe.

▼

8 · Dossier and queue. Evidence assembled into the dossier artefact; identity-level aggregation; ranking by expected cost; delivery to console and webhook.

2.2 Data model and normalisation

Four tables carry the system. Deliberately few — schema sprawl is the most common way a hackathon build runs out of time.

Table	Key columns	Notes

`events`	`id, subject_id, ts, platform, action, resource_id, resource_class, sensitivity, src_asn, src_geo, session_id, raw (JSONB)`	Append-only. Composite index on `(subject_id, ts)` and a partial index on `sensitivity >= high`. This is the only table that grows linearly with the customer.
`subjects`	`subject_id, pseudonym, identity_class, role, cohort_id, employment_state, tenure_days, first_seen`	`identity_class` ∈ {human, service, agent} — the column that makes §4.12 possible without a migration.
`context_records`	`id, source, subject_id, created_ts, created_by, scope_refs[], valid_from, valid_to, payload (JSONB)`	`created_by` and `created_ts` are load-bearing: they implement the provenance and precedence tests. `scope_refs` is the resolved resource list.
`endpoint_events`	`id, subject_id, ts, device_id, process, window_title, resource_path, category, duration_s, presence_state`	Sensor telemetry. Higher volume than the cloud plane by roughly an order of magnitude, so it is partitioned by month and aggregated into per-category rollups for the workforce views.
`captures`	`id, subject_id, ts, device_id, mode, trigger_ref, storage_key, sha256, released_to, released_at`	Screen captures. `mode` is scheduled or triggered. Encrypted at rest under a customer-held key; `released_to` is null until a dual-custody release, so the table is an audit record of who ever saw an image.
`baselines`	`subject_id, feature, median, mad, n_obs, anchor_median, anchor_window, updated_ts`	Both the live and the frozen anchor statistics live here — §2.5 depends on keeping both.

Normalisation collapses vendor-specific action vocabularies into a controlled set of roughly forty canonical actions organised into six families: *authenticate*, *read*, *write*, *export*, *permission*, *administrative*. This matters more than it appears. The trajectory model operates over this alphabet, so its size directly determines the sparsity of the transition matrix — an uncontrolled vocabulary of several hundred raw event types would make order-2 modelling statistically hopeless at realistic data volumes. Collapsing to forty is a modelling decision disguised as a plumbing decision.

2.3 Layer 1 — robust baselines and the cold-start problem

For each identity and each scalar feature (events per day, distinct resources touched, bytes exported, off-hours fraction, distinct platforms, permission changes), we maintain a location and scale estimate.

We use median and median absolute deviation rather than mean and standard deviation. The reason is practical: a single genuine outlier — one legitimate migration day — inflates a standard deviation enough to blind the detector for weeks afterwards. MAD has a breakdown point of 50%, meaning up to half the observations can be arbitrary without destroying the estimate.

$$\mathrm{MAD}_{i,f} = \mathrm{median}(\,|\,x_t - \mathrm{median}(x)\,|\,) \quad \cdot \quad S^{\mathrm{vol}}_{i,f} = |\,x_t - \mathrm{median}_{i,f}\,| \,/\, (1.4826 \cdot \mathrm{MAD}_{i,f} + \varepsilon)$$

The 1.4826 factor makes MAD a consistent estimator of σ under normality, so the resulting score is interpretable on the familiar z-scale. ε prevents division by zero for constant features.

Cold start: hierarchical shrinkage

A new joiner has no history, and this is where naive systems produce their worst week. Every action a new employee takes is unprecedented by definition. Our earlier design had no answer to this beyond a "14-day learning period" during which the system is effectively off — which is also, conveniently, the window in which an onboarding-stage compromise would occur.

Instead we shrink the individual estimate toward the cohort estimate in proportion to how little we know about the individual:

$$\hat{\mu}_{i,f} = w_i \cdot \mathrm{median}_{i,f} + (1 - w_i) \cdot \mathrm{median}_{\mathrm{cohort}(i),f} \quad \text{where} \quad w_i = n_i \,/\, (n_i + k)$$

n_i = observation-days for identity i; $k \approx 10$ is the shrinkage constant, chosen so a new joiner is judged almost entirely against their cohort in week one and almost entirely against themselves by week six. The transition is smooth, with no cliff edge.

This is a standard empirical-Bayes construction, and it costs about ten lines of code. It means tellTale is usefully active on a new identity from day one, judging them against what a person in that role normally does — which is the same judgement a human investigator would make.

2.4 Layer 2 — trajectory modelling

Sessionisation first: events for an identity are split into sessions on an idle gap of 30 minutes, capped at 8 hours, and bounded by explicit session-lifecycle events from the identity provider where available. Each session becomes an ordered sequence of canonical actions `E = (e₁, e₂, …, e_n)`.

We score the sequence by its **surprisal** under an empirical Markov model — the accumulated negative log-probability of the observed path.

$$\text{surprisal}(E) = -\,(1/n)\,\sum_t \ln \hat{P}(\,e_t \mid e_{t-1},\, e_{t-2}\,)$$

Length-normalised so that long sessions are not penalised merely for being long. Exponentiating gives perplexity, which is the form we show analysts because "one in N" is easier to reason about than a log.

Resolving the order conflict: order-2 with backoff

Our source documents contradicted each other on Markov order — one specified first-order, another second-order. Neither is right unconditionally, and the resolution is the interesting part.

First-order is too weak. It cannot distinguish `clone → archive → upload` from `archive → clone → upload`, and that ordering is exactly the signal. Second-order captures it. But with an alphabet of 40 actions, a second-order matrix has 64,000 cells, and a single user over 30 days supplies perhaps a few thousand transitions. Most cells are empty, and an unseen transition would score as infinitely surprising — every session becomes an alarm.

We therefore use **order-2 with Katz-style backoff through a three-level hierarchy**:

$$\hat{P}(e_t \mid h) = \lambda_2\, P_{\text{user}}^{(2)} + \lambda_1\, P_{\text{user}}^{(1)} + \lambda_c\, P_{\text{cohort}}^{(2)} + \lambda_g\, P_{\text{global}}^{(2)}$$

Weights are set by observation counts at each level (more data at a level ⇒ more weight), and sum to 1. Add-α smoothing with α = 0.1 at the global level guarantees no zero probabilities. The population matrix is estimated across all identities, so a transition never seen for this user but common across the organisation is mildly surprising, not impossible — which is the correct semantics.

Two further refinements matter in practice:

- **Time decay.** Transition counts are exponentially decayed with a 45-day half-life, so the model tracks how the organisation actually works now rather than how it worked last quarter, without discarding history outright.
- **Resource-typed actions.** A transition is keyed on the action *and* a coarse sensitivity class of the resource. `export(low)` and `export(critical)` are different tokens. This roughly doubles the alphabet but captures most of what a naive action-only model loses, at acceptable sparsity cost given the backoff hierarchy.

> **WHY NOT A TRANSFORMER**
>
> A sequence transformer would model longer-range dependencies and would probably score a point or two better on a benchmark. We are not using one, for four reasons that survive scrutiny. It needs pre-training data we do not have. It needs GPU inference, which breaks the cost model in §4.5 and the offline-demo requirement in §3.2. It cannot tell an analyst *why* a sequence was improbable, which is the property the entire product is sold on. And a Markov model with proper backoff captures most of the available signal in sessions that are typically 5–40 actions long. We have scheduled transformers for the multi-tenant phase in §4.11, where federated data would actually exist to justify them. Reaching for the heavier model first would be a technology decision pretending to be a product decision.

2.5 Layer 3 — cohort divergence and the slow burn

This is the layer that addresses the hardest part of the problem statement: gradual transitions that individually fall below any threshold. It works by refusing to let the subject influence their own reference point.

The anchor. For each identity we retain a frozen baseline computed over a historical window (default: days 60–90 before present, established at onboarding and re-frozen quarterly under review). Current behaviour is scored against this anchor as well as against the live rolling baseline. A slow-burn attacker moves the rolling baseline with them; they cannot move the anchor.

Peer-relative drift. Absolute drift is ambiguous — if the whole team's activity doubled, that is a release cycle, not fifteen simultaneous insiders. So we measure the subject's drift *net of* their cohort's drift over the same period:

$$D_i(t) = [\ \mu_i(t) - \mu_i^{anchor}\ ] / (\sigma_i^{anchor} + \varepsilon)\ -\ \text{median}_{j \in \text{cohort}(i)} [\ \mu_j(t) - \mu_j^{anchor}\ ] / (\sigma_j^{anchor} + \varepsilon)$$

A positive D means this identity is moving away from where it started in a direction its peers are not moving. Sustained positive D over multiple evaluation periods is the slow-burn signature.

Persistence rather than magnitude. Slow burn is defined by consistency, not size. We apply a one-sided CUSUM over D, accumulating small positive deviations and firing when the cumulative sum crosses a threshold. A +0.4 drift sustained across six weeks accumulates past the bar; a +3.0 spike on one day does not, and is left to the volumetric detector where it belongs. The two detectors deliberately cover complementary regions of the space.

> **THIS IS THE DIRECT ANSWER TO BASELINE POISONING**
>
> The "boiling frog" attack — escalate slowly enough that the moving average absorbs you — defeats every rolling-window detector, structurally and not incidentally. It does not defeat an anchored reference, because the anchor predates the attack and is not updated by it. Re-anchoring is an explicit, logged, reviewed operation rather than an automatic one. That single design choice is what lets us claim slow-burn coverage honestly rather than aspirationally.

2.5.1 The endpoint Sensor and the two detectors it enables

The Sensor is a user-space agent for Windows, macOS and Linux. It installs no kernel driver and hooks no input. It reports five event families — application focus, process execution, file operations, device attach, and presence transitions — normalised into the same canonical action alphabet as the cloud plane, so they become trajectory tokens the existing engine consumes with no modification. That reuse is the point: the Sensor extends coverage into local files, internal tools and legacy applications without adding a second detection path to maintain.

It also makes two detectors possible that cloud telemetry alone cannot support.

Presence divergence

The strongest single signal the Sensor adds, and the cheapest. For each identity we hold a presence state from the endpoint and a stream of authenticated actions from the cloud. When the two disagree — API calls, repository clones or console sessions attributed to a person whose workstation reports idle, locked or offline — the divergence is scored directly:

$$S^{pres} = \sum_{a \in A(t)} w(a) \cdot 1[\ \text{presence}(\text{subject}, t_a) \neq \text{active}\ ]$$

Weighted by action sensitivity, accumulated over the evaluation window, and normalised against the subject's own historical rate of benign divergence — scheduled jobs and legitimately shared service credentials produce a nonzero floor that has to be learned rather than assumed away.

This is the clearest available evidence of session theft, credential sharing, or automation operating under a human identity. It is also close to impossible to produce by accident at volume, which is what makes it worth weighting heavily.

Composition drift

Each application maps to a coarse category — development, browser, communication, file management, administrative, other. A person's category mix over a window forms a distribution, and we track how far it moves from their frozen anchor using Jensen–Shannon divergence, net of the cohort's movement over the same period, exactly as in §2.5:

$$D^{comp}_i(t) = \text{JSD}(\ P_i(t) \parallel P_i^{anchor}\ ) - \text{median}_{j \in \text{cohort}(i)} \text{JSD}(\ P_j(t) \parallel P_j^{anchor}\ )$$

Bounded in [0,1] and symmetric, which makes it stable on the small category alphabet. Sustained positive divergence is the signature: an engineer whose day quietly becomes file management and browsing has changed direction, whatever the volume of their activity.

WHAT IS DELIBERATELY ABSENT FROM BOTH

Neither detector reads the productivity classification. Category *composition* is a behavioural fact; the productive / neutral / unproductive label attached to a category is a management judgement, and it carries no information about data theft. Letting it raise a risk score would be unjustified statistically and corrosive organisationally. The separation is enforced at the feature-extraction boundary: the risk model is not given the column (§1.10.2).

2.6 Layer 4 — context verification engine

The four tests from §1.7, specified for implementation. The engine returns a context verdict `C ∈ {authorised, partial, absent, suspicious}` plus the evidence trail.

Test	Implementation	Failure behaviour
Precedence	`context.created_ts + min_lead < event.ts`, with `min_lead` = 30 min default. Records created after the activity are not merely ignored — they are retained and flagged.	No suppression. Post-hoc creation raises a *retroactive justification* indicator.
Provenance	`context.created_by != subject_id` for full weight. Self-created gets 0.35 weight when the subject has established history in the scope, and 0 weight when they do not.	Weight reduced or withdrawn; self-assignment on novel scope raises the manufactured-context indicator.
Scope match	Resource identifiers in the event are resolved against `context.scope_refs` through a resource map (repository → service → ticket component). Exact or ancestor match required.	Downgraded to *partial*: the anomaly is real but partially explained. Score reduced, not zeroed.
Proportionality	Observed volume compared against the cohort's historical distribution of volume for similarly-scoped work. Flags when activity exceeds the 95th percentile for that work class.	Suppression capped — a valid ticket can reduce risk by at most a bounded factor, never to zero.

The resulting multiplier enters fusion as an additive logit term rather than a raw multiplier, which keeps the whole model in one interpretable space:

$$\gamma_{\text{authorised}} = -2.6 \;\cdot\; \gamma_{\text{partial}} = -1.1 \;\cdot\; \gamma_{\text{absent}} = 0 \;\cdot\; \gamma_{\text{suspicious}} = +2.2$$

These are initial values fitted on the simulator, not universal constants — §2.7 explains the fitting procedure and why we no longer present such numbers as though they were physics.

Two hard invariants, both learned from thinking about how this gets abused:

- **Context never fully zeroes a score.** Suppression is bounded. A deterministic signal — a honeytoken touch, a known-malicious egress destination — is exempt from suppression entirely.
- **Every suppression is recorded.** Suppressed events remain queryable with their reason. This is what makes the false-positive reduction claim in §2.10 auditable, and it means a manufactured context discovered later exposes everything it hid.

2.7 Layer 5 — risk fusion and calibration

Sub-scores combine through a logistic model over standardised features:

$$P(\text{malicious} \mid \text{evidence}) = \sigma\left(\beta_0 + \sum_k \beta_k S_k + \sum_j \gamma_j C_j \right)$$

S_k: the seven primitive sub-scores, each clipped to a bounded range to prevent any one detector from saturating the sum. Where the Sensor is absent, the two endpoint terms are dropped and the model falls back to a five-feature coefficient set fitted on cloud-only data — not to zeroes, which would silently bias every score downward. C_j: context indicator terms.

Where the coefficients come from

Our earlier drafts stated specific coefficients (−2.8, +3.5, −3.0) with no account of their origin. That is not defensible, and a reviewer is entitled to ask. Coefficients are obtained one of two ways, and we say which applies:

1. **Fitted**, by maximum likelihood on the labelled simulator corpus, with L2 regularisation and a monotonicity constraint forcing every $\beta_k \geq 0$ — more anomaly must never reduce risk. Fitting is done on the development split only.
2. **Prior-seeded**, where a detector is too rare in the corpus to fit reliably (honeytokens, by construction, produce few positives). These are set from stated reasoning and marked as priors in the configuration file, so nobody later mistakes them for learned values.

Every coefficient in the shipped configuration carries a provenance tag, `fitted` or `prior`, and the fitting script is part of the repository. If a judge asks where +2.4 came from, the answer is a file and a command, not a shrug.

Calibration

A logistic output is not automatically a calibrated probability. We fit an isotonic regression on a held-out split mapping raw model output to observed frequency, so that among alerts scored 0.80, roughly 80% are in fact malicious. Calibration is what makes the number meaningful across teams and over time, and it is what makes the expected-cost ranking in §1.10 arithmetically valid rather than decorative. We report a reliability diagram and Brier score alongside detection metrics, because a well-ranked but badly calibrated model would quietly break prioritisation.

The displayed 0–100 score is simply the calibrated probability times 100. There is no hidden scaling, no vendor-specific risk arithmetic, and no severity multiplier baked into the number.

2.8 Explainability by construction

Because fusion is additive in logit space over interpretable features, the contribution of each feature is exactly `β_k · S_k`. No approximation is required. This is worth stating plainly because it is a real architectural advantage: methods like SHAP exist to approximate feature attribution for models that cannot produce it directly. We chose a model that produces it directly, which is faster, exact, and removes a dependency.

The explanation surfaces at three depths:

- **Analyst view** — ranked contributions in plain language, as in the §1.9 dossier.
- **Engineer view** — the raw feature vector, the baselines used, the specific transition probabilities consulted, and the context records evaluated with their test results.
- **Audit view** — an immutable record of model version, coefficient set, calibration map and input hash, so any historical decision can be reproduced exactly. Necessary for any regulated customer, and cheap to build if done from the start rather than retrofitted.

2.9 API surface and tech stack

Stack	
Backend	Python 3.12 · FastAPI · Pydantic v2
Datastore	PostgreSQL 16 (JSONB for context payloads)
Persistence layer	SQLAlchemy 2.x · Alembic migrations
Numerics	NumPy · SciPy · scikit-learn
Trajectory model	Hand-rolled Markov with backoff (NumPy)
Simulator	Python, writes directly to Postgres
Frontend	Next.js 16 (App Router) · TypeScript

Core endpoints	
`POST /events`	Ingest, normalise, persist
`GET /subjects`	Ranked queue with current risk
`GET /subjects/{id}/dossier`	Run pipeline, return full evidence
`GET /subjects/{id}/timeline`	Event series for the chart
`GET /subjects/{id}/graph`	Nodes and edges for the path view

UI	Tailwind CSS · shadcn/ui · Recharts · React Flow
Data fetching	TanStack Query
Packaging	Docker Compose — one command, fully offline

`GET /suppressions`	Audit log of gated alerts (console: Approved Activity)
`POST /subjects/{id}/feedback`	Analyst verdict + reason code
`POST /actions/revoke`	Containment (mocked in demo)
`GET /health/connectors`	Heartbeat status per source
`GET /model/card`	Version, coefficients, provenance

One database, deliberately. Our deep research architecture specified Kafka or Redpanda for streaming, ClickHouse for columnar analytics and Redis for hot state. That is the right architecture at tens of thousands of identities. It is the wrong architecture at our current scale, where the entire workload is a few million rows. PostgreSQL with a composite index on `(subject_id, ts)` returns 90-day trajectory queries in single-digit milliseconds here. Adding three stateful services would cost days of our build time and change nothing a reviewer can observe. We have written down the migration trigger — sustained ingest above roughly 2,000 events per second, or p95 query latency above 200ms — so the decision to add them later is a measurement, not a preference.

2.9.1 Console ergonomics

The console is the thing a judge, a design partner and a 2am analyst all actually touch, so it earns its own specification rather than being left as "a Next.js app". Three properties are load-bearing.

Dual-theme system

Light mode for daytime use and executive review; a high-contrast dark mode purpose-built for a 24/7 SOC desk, where a bright interface at 3am is a real usability complaint, not a preference. The toggle persists client-side and swaps with no flash of unstyled theme on load. Tokens are fixed, not vibes:

Token	Light	Dark	Role
Canvas	`#F8FAFC`	`#090D16`	Page background
Card surface	`#FFFFFF`	`#0F172A`	Panels, tables, dossier cards
Border / hairline	`#E2E8F0`	`#1E293B`	Dividers, table rules
Text, primary	`#0F172A`	`#F8FAFC`	Body and headings
Text, secondary	`#64748B`	`#94A3B8`	Captions, metadata
Accent	`#059669`	`#10B981`	Active states, links, healthy indicators
Alert	`#EF4444`	`#EF4444`	Critical risk, failed checks
Warn	`#F59E0B`	`#F59E0B`	Partial context, degraded connectors

Instant search and multi-column sort

Every operational table — Review Alerts, the Team Overview roster, Screen Captures, App Usage, Approved Activity — carries the same two controls: a debounced instant search over the visible columns, and a sort control with a table-appropriate set of modes (Review Alerts sorts by priority score or age; Team Overview by roster order, name, team or top application; Screen Captures by newest, oldest, member or application). Consistency here is deliberate — an analyst who has learned one table has learned all of them.

Collapsible navigation rail

The sidebar has two states: a full drawer with labels, and a 64-pixel icon rail with hover tooltips, for analysts who want the evidence panel wider than the chrome around it. State persists per user.

2.10 Evaluation protocol — the honest version

> **A CORRECTION WE ARE MAKING EXPLICITLY**
>
> Earlier drafts of this work claimed **0.942 AUROC validated on the CMU CERT insider threat dataset**. We are removing that claim. We had not run that evaluation, and the same documents elsewhere correctly assess CERT as unsuitable for validating a cloud/SaaS-era system — it is synthetic, dates from 2011, and contains no SSO, MFA, repository or SaaS events. Presenting an unearned number from an unsuitable dataset is worse than presenting none. What follows is what we are doing instead.

The corpus

A synthetic organisation of 100 identities across six functions, generated over 90 simulated days, with role-conditioned daily routines, weekly and diurnal rhythm, project churn, on-call rotations, genuine promotions and team transfers, and a realistic rate of benign-but-unusual activity — migrations, audits, incident response, contractor onboarding. The benign-but-unusual population is the part that matters: a corpus containing only obvious normality and obvious attacks makes any detector look excellent.

Four rules that make the result mean something

Rule	Why
Separated authorship	Attack scenarios are written by team members who are not tuning the detector, from a written threat brief, without sight of the detector's features. Self-authored attacks against a self-tuned detector measure nothing but the author's imagination.
Held-out attack family	One entire attack class is sealed until evaluation day and never used during development. Performance on seen families measures fit; performance on the unseen family measures generalisation. We report both, separately, and expect the second to be worse.
Naive control detector	We implement the thing we are criticising: per-user rolling mean, alert at μ+3σ, no context. Both run over identical data. This gives the false-positive-reduction claim an actual denominator.
Time and user disjoint splits	Fitting on days 1–60, evaluation on days 61–90, with a disjoint identity set. Prevents both temporal leakage and memorisation of individuals.

Metrics we report

Metric	Why this one
Alerts per analyst per day at fixed recall	The primary metric. Fix recall at 0.90 against the attack set, then report alert volume. This is the number that decides whether a real team keeps the tool switched on. AUROC does not.
Precision@10	The top of the queue is all most teams ever reach. Precision in the tail is academic.
Median time-to-detection	Measured from the first malicious action, not the last. For slow-burn scenarios this is the whole question — detecting on day 58 of a 60-day exfiltration is a failure that scores as a success on accuracy.
Suppression precision	Of alerts suppressed by context, what fraction were genuinely benign? A high-recall system that suppresses true positives has moved the failure somewhere less visible, not fixed it.
Calibration: Brier score + reliability diagram	Confirms the score is a probability. Required for expected-cost ranking to be valid.
Evasion resistance	Adaptive attackers who know the design (§2.11), scored separately. Reported even where we do poorly — this is the section where honesty is most informative.

Results are recorded in Appendix C. We publish the harness and the seed so any run is reproducible. We regard a detection system whose evaluation cannot be reproduced as an assertion rather than a result — including when it is ours.

2.11 Adversarial robustness

We assume the adversary has read this document. Detection systems face an intelligent opponent, and any robustness claim that assumes ignorance is worthless.

Attack	Defence	Residual exposure
Baseline poisoning Escalate slowly so the rolling window absorbs it	Anchored reference window plus peer-relative CUSUM (§2.5). The subject cannot move the anchor.	An attacker who begins poisoning *before* the anchor is established — i.e. from their first day. Mitigated by cohort shrinkage (§2.3), not eliminated.
Context manufacturing Create authorisation to earn suppression	Four-test verification and a dedicated detector for the manufacturing pattern (§1.7, §2.6).	Collusion — a genuine second party assigns the ticket. Partially addressed by graph topology and proportionality, not fully solved. We say so rather than claiming otherwise.
Telemetry starvation Disable connectors or delete audit trails	Dead-man heartbeats per connector with expected-volume bands. Silence or an unexplained volume drop raises a severity-1 *within* 15 minutes. Absence of data is itself a signal.	Selective tampering upstream of our collection point, in the platform's own audit pipeline.
Living off the land Use only permitted tools and commands	This is the primary design target. Individual authorisation is irrelevant to trajectory surprisal — only the path is scored.	An attack whose path closely mimics a common legitimate workflow against a legitimate resource.
Cohort camouflage Join a high-activity team to raise the peer baseline	Cohort membership changes are themselves context events with precedence and provenance. A transfer triggers a re-anchoring review rather than an automatic reset.	A genuine transfer engineered months ahead. Long-horizon, high-effort.
Low-volume precision theft Take three files that actually matter	Volumetric detection cannot see this and we do not pretend it can. Coverage comes from asset criticality weighting, honeytoken placement in high-value locations, and scope verification.	**Genuinely hard.** Small, targeted, authorised-scope theft is the weakest point of any behavioural system, ours included.

That last row is the honest boundary of the approach. Behavioural detection is weak against a patient insider taking a small number of files strictly inside their legitimate scope; the answer there is deception and data-layer controls, not more modelling. A vendor who claims otherwise is selling.

2.12 Privacy architecture

Privacy here is structural, not a settings page. Three mechanisms, applied in this order:

1. **Pseudonymisation at ingestion.** Identifiers are replaced with salted HMAC pseudonyms before anything is persisted, keyed by a customer-held secret. The console displays `#4912`, and our infrastructure never stores the mapping in plaintext — so a breach of our systems identifies nobody.
2. **Dual-custody unmasking.** Revealing an identity requires two independent approvals from separate functions — typically security and legal or HR. The request records probable cause; the grant is time-limited; the whole transaction is written to an append-only log that the subject's representatives can audit. The default answer to "who is #4912" is that nobody currently knows.
3. **No content, ever.** The engine reads metadata: actor, action, resource identifier, timestamp, source. Not file contents, not message bodies, not source code, not screen state, not keystrokes. This is enforced at the normalisation boundary — content fields are dropped before persistence, so the capability does not exist to be misused or subpoenaed.

CONSISTENCY CHECK

Our earlier documents described pseudonymisation and then printed a dossier naming "Bob Miller, DevOps Lead". That inconsistency is fixed throughout: every artefact in this document, including the §1.9 dossier and the demo, shows pseudonymous subjects with the unmasking workflow visible as a deliberate step. If the demo shows a name, the architecture is decorative. It should cost something to learn who someone is.

2.13 What we deliberately did not build

Scope discipline is a technical decision. Each exclusion below carries a trigger that would justify revisiting it.

Excluded	Why not now	Revisit when
Kafka / Redpanda, ClickHouse, Redis	Three stateful services for a workload Postgres handles comfortably	Sustained ingest > 2,000 eps or p95 query > 200ms
Transformers, graph neural networks	No pre-training corpus; breaks explainability and the cost model	Multi-tenant federated data exists (roadmap phase 3)
SHAP or post-hoc attribution	Unnecessary — our model yields exact attributions directly	Only if a non-additive model is introduced
Live OAuth integrations and a production Sensor binary	Registration cycles and code-signing cost days; a faithful mock and a simulated Sensor feed are functionally identical for evaluation	First design partner signs
Kernel drivers, input hooks, keystroke capture	Permanent exclusion, not a scope decision — poor signal, high liability, and the line that keeps the Sensor negotiable in Europe	Never
HSM-backed key management	Correct for production; irrelevant to demonstrating detection	First customer handling regulated data
Automated enforcement without approval; console accounts and RBAC	Unattended revocation is wrong by default — a false positive that cuts a CTO's session at 2am ends the pilot. Account management is pure overhead in a single-operator demo.	Enforcement: after a sustained measured precision record, opt-in per action class. RBAC: at multi-analyst deployment.

PART THREE

Feasibility

Feasibility has two horizons and they demand different answers. The near horizon is whether two of us can demonstrate this working within the competition's constraints. The far horizon is whether the same design survives contact with a real enterprise — rate limits, cost, law, and the people being monitored. Both are addressed here, in that order.

3.1 Current status: what exists and what is asserted

We separate these deliberately, because a reviewer's trust is worth more than a marginally better claim.

Component	Status	Note
Problem analysis and competitive teardown	Complete	Six vendor archetypes examined against primary documentation and practitioner reporting.
Detection design and mathematics	Complete	Fully specified in Part 2; every formula implementable as written.
Schema and API contract	Complete	Four tables, ten endpoints. Frozen before implementation starts.
Synthetic corpus generator	In progress	Role-conditioned routines and rhythm working; benign-but-unusual population being expanded.
Detection engine	In progress	Baseline and trajectory layers implemented and unit-tested; context and fusion in build.
Console	In progress	Queue and dossier views; timeline and path graph next.
Measured evaluation results	Not yet produced	Protocol fixed (§2.10); harness built; numbers will be reported in Appendix C when the run completes. We are not estimating them in advance.
Live platform integrations	Out of scope	Deliberate (§2.13). Mocked with faithful response shapes.

3.2 The 36-hour build plan

CyberForge moves from coding to idea submission to a live product presentation, and every stage rewards a working demo. We therefore plan the build as a time-boxed **36-hour sprint** and prepare for it now, because the constraint is not skill but preparation. The plan assumes the brief we finally build against may be narrower than, or different from, this document.

Window	Objective	Detail
H0 – H2	Decompose and map	Parse the brief against our existing component inventory. Decide what is reused verbatim, what is adapted, what is genuinely new. Freeze scope in writing. No code in this window — this is the window most teams waste by starting immediately.
H2 – H6	Data first	Adapt the simulator to whatever entities the brief implies. Everything downstream needs data to build against, so this precedes API and UI work without exception.
H6 – H14	Detection core	Port the baseline, trajectory and fusion modules. These are domain-independent (§3.3). Adapt features and the context source to the new domain.

H14 – H18	Integration checkpoint	**Hard gate:** end-to-end path must work — data in, score out, one rendered view. If it does not, we cut scope here rather than at hour 30. This checkpoint exists to make the failure cheap.
H18 – H26	Interface	Queue, dossier, timeline, path graph. Component library is pre-installed; no design work happens mid-sprint.
H26 – H31	Scenario polish	The three-subject comparison adapted to the new domain. Pre-loaded demo buttons so nothing depends on live typing.
H31 – H34	Hardening and rehearsal	Full offline run on a clean machine. Record a backup walkthrough video. Rehearse the pitch aloud three times minimum.
H34 – H36	Freeze	**Zero code changes.** Sleep is a performance input. A team that debugs in the last two hours presents badly regardless of what they fixed.

THREE PREPARATIONS THAT MAKE THIS PLAN WORK

- **Pre-built scaffold.** A repository with Docker Compose, Postgres, FastAPI skeleton, Next.js with shadcn/ui installed, and the detection modules as importable packages. Hour zero starts with a running system, not `create-next-app` .
- **Everything runs offline.** Docker Compose on a laptop with no network dependency. Venue wifi is removed as a failure mode entirely, which also protects the demo.
- **Dependencies vendored.** Node modules and Python wheels cached locally before arrival. Package registries being slow or blocked is a real and common demo-day failure

3.3 Portability to other detection problems

Because the final brief may differ from this document, and because the same engine should serve other detection problems, we classified our own work by how much of it survives a change of problem. This shaped where we invested effort.

Component	Portability	Reasoning
Robust baselining, shrinkage	**Universal**	Any behavioural security problem needs "what is normal for this entity" — no assumption about insiders at all.
Trajectory / sequence scoring	**Universal**	Applies to any ordered event stream: fraud, abuse, supply-chain, network. The alphabet changes; the machinery does not.
Risk fusion and calibration	**Universal**	Pure combination layer over sub-scores.
Dossier renderer, console, graph view	**Universal**	Evidence presentation is domain-agnostic. This is also the strongest visual asset we have.
Context verification engine	**High**	The four tests generalise; the context *sources* would change with the domain.
Simulator	**Medium**	Architecture reusable, entity and action definitions rewritten. Budgeted at four hours in §3.2.
SaaS connector semantics	**Low**	Specific to identity and SaaS telemetry — which is precisely why they are mocked rather than built.

Roughly three-quarters of our engineering effort sits in universally portable components. That is not an accident; it is why we declined to spend the first build phase on real OAuth integrations, which a faithful mock replaces for evaluation.

3.4 Team allocation

Two members, with responsibilities split along a clean interface so that work runs in parallel and neither person is a blocking dependency. Aarav owns everything that produces a score; Aankhi owns everything that tests, shows and explains it.

Member	Primary ownership	Scope
Aarav Gupta	**Detection engine and data platform**	Baselines, trajectory model, fusion and calibration; schema, normalisation, ingest API and query performance. Owns the coefficient-fitting script.
Aankhi Roy	**Simulator, evaluation, console and narrative**	Corpus generation, evaluation harness and metrics, Next.js console, context verification and the pitch. Holds the held-out attack family.

The separation between Aankhi's attack authorship and Aarav's detector tuning is a methodological commitment, not a convenience of scheduling. It is what makes our evaluation numbers mean anything (§2.10), and we would rather lose a point of measured performance than lose the ability to defend the measurement.

3.5 Real-world deployment feasibility

Whether this works outside a simulator turns on four practical questions.

Do the APIs actually provide what we need?

Yes, and this is verifiable from public documentation rather than assumed. Okta's System Log API exposes authentication, MFA outcome, session lifecycle and token events. Google Workspace Reports provides Drive, Admin and login activity. GitHub Enterprise exposes an audit log covering clones, permission changes and token creation. AWS CloudTrail records API-level actions with actor and resource. Jira and common HR platforms expose issue and employment-lifecycle events. Every signal Part 2 depends on is available through a documented, read-only interface. No signal in our design requires a capability that does not exist.

Do rate limits permit it?

This is the most common way an API-first design fails in production, so it is designed for explicitly rather than discovered later. Audit APIs are generally rate-limited per tenant. Mitigations, in order of preference: webhook or pub/sub push where the platform supports it, so no polling budget is consumed; cursor-based incremental polling on a staggered schedule where it does not; a per-connector token-bucket budget with exponential backoff and jitter; historical backfill throttled and scheduled at onboarding rather than competing with steady-state collection. The throughput we require — order 40 million events per month for a 2,000-person organisation, roughly 15 events per second average — is well inside documented limits when collection is incremental.

Is the detection latency acceptable?

All detection is arithmetic over pre-computed tables. A full scoring pass for one identity is a handful of array lookups, a MAD comparison and a logistic evaluation — sub-millisecond in NumPy. The dominant latency is collection, which is bounded by platform push or poll interval, typically one to five minutes. Sub-minute end-to-end detection is reachable for push-enabled sources. Critically, there is no model inference step in the hot path, so latency does not degrade under load in the way a GPU-backed pipeline does.

Can the Sensor actually be deployed?

This is the new question the endpoint plane creates, and it is an operations question rather than a technical one. The Sensor is a signed user-space binary distributed through whatever MDM the customer already runs — Intune, Jamf, Workspace ONE — which is the same channel their existing endpoint agents use, so it adds a step to an established process rather than a new process. Footprint target is under

1% CPU at idle and under 80MB resident. It buffers to local disk when offline and backfills on reconnect, so a laptop that spends a week on a plane loses nothing. Realistic time to full fleet coverage is days to two weeks depending on fleet size and MDM maturity — which is precisely why the cloud plane ships first and alone (§4.7), so the customer is already convinced before they schedule a rollout.

Does the cost structure hold?

The cloud plane is cheap: roughly 350 bytes per normalised event, about 14GB of warm data per month for a 2,000-person organisation, tiering to compressed object storage. Call it ₹350–420 per identity per year.

The Sensor changes this materially and we should not pretend otherwise. Endpoint telemetry runs roughly an order of magnitude higher in event volume than the cloud plane, and scheduled screen capture dominates everything else: at a five-minute cadence during active hours, one identity generates on the order of 2,000 images a month, and at ~150KB each that is ~300MB per identity per month of new data. With a 90-day retention window the steady-state footprint is close to 900MB per identity, which is roughly three orders of magnitude more storage than the metadata it accompanies.

Blended across a realistic tier mix this takes estimated infrastructure cost from about ₹350 to about **₹1,150** per identity per year, and support allocation from ₹175 to about ₹290 once there is an agent to support. Both figures are *derived* from the assumptions above rather than measured, at an assumed ₹83/US$1 cross-reference. §4.5 carries the revised margin, and retention policy — not capture cadence — is the dominant lever on it.

3.6 Performance and scaling envelope

Dimension	Current design	Limit and next step
Identities per instance	Up to ~5,000	Beyond this, partition by tenant; baselines are per-identity and embarrassingly parallel.
Ingest rate	~500 events/sec sustained on a single Postgres node with batched inserts	At 2,000 eps introduce a streaming buffer; this is the documented migration trigger from §2.9.
Trajectory query, 90 days	Single-digit ms with `(subject_id, ts)` index	At >100M rows per tenant, partition by month or move analytics to a columnar store.
Scoring pass, full population	100 identities in well under a second	Linear in identities; parallelises trivially across workers.
Model retraining	Minutes on CPU	Never a scaling constraint — this is a direct benefit of not using deep models.

3.7 Inclusivity and fairness

A behavioural monitoring system assigns suspicion to people. Getting this wrong does not merely produce bad metrics; it produces unfair treatment of identifiable individuals, concentrated on those who already deviate from an implicit norm. We treat this as a first-class design concern, and it also happens to be a significant source of false positives — the ethical and the technical fix are the same fix.

Population at risk	How a naive system harms them	Our handling
Distributed teams across time zones	"Off-hours activity" is defined against headquarters hours, so an engineer in another time zone is permanently anomalous.	Working hours are learned per identity from observed history, never configured globally. Time-zone novelty is evaluated against the individual's own pattern.
Assistive technology users	Screen readers, voice control and automation tools produce distinctive event rates and patterns that read as scripted or automated.	Volumetric features are per-identity and shrunk toward cohort, not absolute. Rate anomalies alone never escalate without corroboration from an independent primitive.

Contractors and new joiners	No history means everything is unprecedented; they are flagged constantly in their first weeks.	Hierarchical shrinkage (§2.3) judges them against role-appropriate cohorts from day one.
Shift workers and on-call staff	Night activity is inherently suspicious under a day-shift assumption.	On-call rotation is a first-class context source. Night work during a rotation is expected behaviour, not an exception granted by a rule.
People whose job recently changed	The single largest driver of legitimate anomaly, and the one legacy tools handle worst.	Role change is a context event that triggers a supervised re-anchoring rather than a sustained alert storm.
Everyone, against opaque scoring	Being unable to contest an automated judgement is itself a harm, and a legal exposure.	Pseudonymity by default; dual-custody unmasking; full contribution breakdown available to any review process (§2.12).

Fairness auditing

We report alert rate broken down by cohort, tenure band and working-hours pattern. If any group receives alerts at a materially disproportionate rate without a corresponding difference in confirmed findings, that is a defect in the detector and is treated as one. This audit is part of the evaluation run, not a compliance artefact produced afterwards, and its output goes in Appendix C alongside the detection metrics.

A GUARANTEE WE CAN NO LONGER MAKE THE EASY WAY

Earlier drafts of this document claimed that tellTale "collects no signal that would support" productivity measurement or performance review, and argued that when data cannot support a misuse, policy against that misuse need not be trusted. With the Sensor and the workforce module, **that claim is no longer true** and we are not going to leave it standing.

The guarantee moves from architectural to governance, and becomes correspondingly weaker and more demanding. What replaces it: the productivity classification is not exposed to the risk model at the feature-extraction boundary; the workforce and security surfaces carry separate role grants; crossing between a named employee and a pseudonymous subject requires dual-custody approval and is logged; and the fairness audit above is extended to cover the workforce module, not only the detector.

A customer who wants to misuse this product now can, by granting one person both roles. We can make that difficult, visible and auditable. We cannot make it impossible, and saying otherwise would be false.

3.8 Legal and regulatory feasibility

For an enterprise security product, legal feasibility is commercial feasibility. A deal dies the same whether it dies in security review or in works-council consultation.

Regime	Requirement	How the design satisfies it
GDPR Art. 6 / 88 Lawful basis; employment context	Processing must be necessary and proportionate; member states impose additional employment-specific rules.	Metadata minimisation, pseudonymous default, documented purpose limitation, bounded retention. Legitimate-interest assessment is materially easier when no content is processed.
GDPR Art. 9 Special categories	Biometric data for identification requires an Art. 9 condition.	Not applicable — we rejected all biometric signals (§1.5). This is the direct payoff of that rejection.
GDPR Art. 22 Automated decisions	Rights around solely automated decisions with significant effects.	Human in the loop by default; no automated adverse action on an individual without review; exact contribution breakdown available for any contest.

German works council co-determination	Systems capable of monitoring employee performance or conduct require agreement with the works council.	No keystroke or content capture, and no screen capture by default; pseudonymity by default; dual-custody unmasking gives the council an auditable, enforceable control. The optional capture module is triggered rather than continuous, which is the form a works agreement can realistically cover.
India DPDP Act 2023 and DPDP Rules 2025	Consent, or one of the listed legitimate uses. Security safeguards, erasure on purpose completion, breach notification.	s.7(i) covers this processing without consent — see §3.8.1. Our exposure is the safeguards duty, not the lawful basis. Data residency achievable through single-tenant deployment.
EU AI Act	Systems used for monitoring in employment contexts attract elevated obligations.	Full explainability, documented evaluation and fairness auditing, model cards with versioned coefficients — the documentation burden is largely already discharged by §2.8 and §2.10.

The strategic point: competitors built on continuous screen recording and keystroke capture carry a negotiation burden in Europe that we do not. Our refusals in §1.5 cost us signal we assessed as low-value and buy us a shorter path through legal review. That is a favourable trade, and it was made deliberately rather than discovered.

3.8.1 Deployment profiles

Because collection now spans metadata, presence and imagery, a single global configuration cannot be lawful everywhere. tellTale ships **jurisdiction profiles**: named collection configurations applied per deployment, with each setting traceable to the legal basis that supports it. A profile is chosen at onboarding and changing it is a logged administrative act requiring two approvals.

Profile	Collection enabled	Basis and conditions
Full *India, US*	Cloud plane, Sensor metadata, presence, scheduled capture, triggered capture, workforce module.	India: DPDP s.7(i) — both limbs. The employment limb supports the workforce module; the loss-and-liability limb supports the detection engine. US: company-device policy with notice and acknowledgement at onboarding.
EU standard	Cloud plane, Sensor metadata, presence, triggered capture. **Scheduled capture off.** Workforce module limited to aggregate reporting.	GDPR Art. 6(1)(f) with a documented legitimate-interest assessment and a DPIA, plus Art. 88 national employment rules. Continuous capture is the specific control that fails the proportionality test; triggered capture passes it because the system is dormant until behaviour justifies it.
Works agreement *Germany, and equivalents*	As EU standard. Any capture, application-level reporting, or individual-level workforce view requires the negotiated agreement and the exclusion lists it specifies.	BetrVG s.87(1) No. 6. The profile ships with a draft works agreement and a machine-readable exclusion list, so the negotiation starts from a document rather than from zero. This is a sales asset, not only a compliance one.
Forensic only	Cloud plane and triggered capture. No scheduled capture, no workforce module, no individual reporting.	For customers whose works council or internal policy permits incident response and nothing else. Also our own recommended default for engineering-heavy organisations, where blanket monitoring is culturally expensive and rarely worth the signal.

The profile mechanism is the honest answer to a real problem: we are now shipping capabilities that are lawful in Bengaluru and Austin, conditionally lawful in Munich, and commercially unwise in a San Francisco engineering org regardless of legality. Configuration is where that gets resolved, and making it explicit and auditable is better than a settings page nobody reads.

3.8.2 India in detail

India deserves its own treatment. It is our home market, the regulatory clock there has only just started, and — contrary to what our earlier drafts asserted — it is the **most permissive** of the three regimes above for exactly this kind of processing.

The lawful basis is unusually clear

Section 7 of the DPDP Act lists legitimate uses for which no consent is required. Clause (i) covers processing for the purposes of employment, or to safeguard the employer from loss or liability, and gives as its examples the "prevention of corporate espionage", the confidentiality of trade secrets, intellectual property and classified information. That is not a grudging carve-out; the statute names our use case. Unlike GDPR Art. 6(1)(f), there is no balancing test attached — these are categorical exemptions.

The clause has **two limbs**, and that matters now that we ship both modules. The loss-and-liability limb, with its security-specific examples, supports the detection engine. The broader "purposes of employment" limb is what supports the workforce module — usage reporting, attendance, working time. Indian employers already rely on it for exactly this, and it is the reason a combined product is straightforward to deploy in India in a way it is not in Germany.

Three things that are simply absent

- **No special-category regime.** The DPDP Act treats all digital personal data alike. There is no analogue to GDPR Art. 9 and no inheritance of the sensitive-data list from the SPDI Rules 2011. Our earlier claim that keystroke dynamics are "biometric data under the DPDP Act" was wrong; they are ordinary personal data, and the case against collecting them in India is signal quality.
- **No works-council equivalent.** There is no statutory co-determination over workplace monitoring. The employment contract and the acceptable-use policy are the operative instruments.
- **No automated-decision-making right.** The Act contains nothing like GDPR Art. 22. We hold the human-in-the-loop design anyway, because it is right and because it travels.

What does bind us

Section 8(5) requires reasonable security safeguards and carries the highest penalty cap in the Act. Section 8(7) requires erasure once the purpose is served, which makes our retention policy the compliance artefact rather than a footnote. Breach notification runs to the Board and to affected principals. The IT Act 2000 and the SPDI Rules 2011 remain operative alongside. Puttaswamy (2017) established privacy as a fundamental right under Art. 21, but it runs against the State; horizontal application to a private employer is limited, though its proportionality reasoning shapes how courts read reasonableness in employment disputes.

Commencement — and why the timing favours us

The DPDP Rules 2025 were notified on 13 November 2025 with staggered commencement: the Data Protection Board provisions took effect immediately, consent-manager registration at twelve months, and the substantive Data Fiduciary obligations eighteen months from publication — which computes to around May 2027. Indian organisations are therefore squarely in scope today and not yet in breach of anything. That is a selling window, not an obstacle: buyers need to demonstrate safeguards before the clock runs out, and a system that is minimising by construction is easier to stand behind than one retrofitted under deadline.

> **THE NUANCE THAT DECIDES HOW FAR S.7(I) STRETCHES**
>
> Every example in clause (i) is defensive and security-specific. A credible reading — argued publicly by Indian practitioners, and the subject of a live constitutional critique on vagueness and overbreadth grounds — is that the clause does not extend to continuous keystroke logging or blanket surveillance of an entire workforce, because none of its examples describes anything of the sort.
>
> This is where shipping both modules costs us something, and it is worth being clear about what. The detection engine sits in the middle of what the loss-and-liability limb contemplates. Scheduled capture for workforce reporting relies on the broader employment limb, which is the part under constitutional challenge for vagueness and overbreadth. If that challenge succeeds or the clause is read down, our detection capability is unaffected and our scheduled-capture capability in India may not be.
>
> The profile mechanism in §3.8.1 is what makes that survivable: the workforce module is a configuration, not a foundation, and a customer moved from Full to Forensic-only keeps a working security product. We would rather carry that as a known, bounded exposure than build a product where an adverse reading of one statutory limb takes the whole thing down.

This is our own reading of publicly available statutory text and practitioner commentary, not legal advice, and the commencement dates are computed rather than officially confirmed. Any deployment would be reviewed by counsel. We include it because a security product sold into Indian mid-market firms will be asked these questions in the first meeting.

3.9 Risk register

Risk	Likelihood	Impact	Mitigation

Evaluation shows insufficient false-positive reduction versus the naive control	**Medium**	**High**	This is the point of running the control. If the gap is small, the honest response is to report it and diagnose which layer underperformed — most likely context coverage, which is measurable and fixable.
Simulator realism gap — real telemetry is messier than generated telemetry	**High**	**Medium**	Explicitly acknowledged. Benign-but-unusual population is the main defence; a retrospective audit on a design partner's real historical logs is the first commercial milestone precisely because it closes this.
Context sources incomplete at a real customer — tickets not used consistently	**High**	**Medium**	Context absence is treated as neutral, never as evidence of guilt. Coverage is measured and reported to the customer as an onboarding metric, which also drives their own process improvement.
Final brief differs from what we prepared for	**Medium**	**Medium**	§3.3 portability analysis; ~75% of components are domain-independent. H0–H2 mapping window exists for exactly this.
Demo failure live — network, dependency, or environment	**Medium**	**High**	Fully offline Docker Compose, vendored dependencies, recorded backup video, clean-machine rehearsal.
Incumbent bundles equivalent capability	**Medium**	**Medium**	Addressed commercially in §4.10 — the defensible asset is the context graph and the non-Microsoft stack, not the algorithm.
Scope creep during the 36-hour build	**High**	**High**	Written scope freeze at H2; hard integration gate at H14; named owner empowered to refuse additions. Historically the most likely cause of a failed hackathon build, ours included.

3.10 Kill criteria

Stating in advance what would falsify the idea is the strongest available evidence that we are not merely advocating for it. Each of these is measurable and each has a date.

1. **Suppression does not work.** If context gating fails to remove at least half of the naive control's false positives at equal recall on our corpus, the central thesis is wrong and no amount of engineering rescues it.
2. **Slow burn stays invisible.** If anchored cohort divergence does not detect a 60-day gradual exfiltration before day 30, we have not solved the problem we claimed was unsolved.
3. **Explanations do not accelerate triage.** If test users cannot reach a correct verdict from a dossier in under five minutes, the explainability claim collapses and with it the differentiator.
4. **Tuning burden is unchanged.** If a pilot requires more than five hours per week of rule tuning after the initial baseline period, we have rebuilt the thing we criticised.
5. **Nobody converts.** If ten retrospective audits produce fewer than two paid contracts, the willingness to pay is not there regardless of technical merit.

Criteria 1–3 are testable on our own corpus before any customer exists, which is the point of designing the evaluation before the marketing. Criteria 4–5 belong to the commercial phase in Part 4.

PART FOUR

Business Strategy

4.1 Category and buying reality

An uncomfortable fact governs everything in this part: **no security buyer has a budget line for "behavioural transition detection."** It is a capability, not a procurement category. A product that insists on being described by its mechanism will lose to a product that is described by the buyer's problem.

tellTale is therefore sold into two established budget lines — **Identity Threat Detection and Response** and **Insider Risk Management** — and positioned at their intersection. Both are live line items with named owners. The mechanism is what we build; the category is how we get in the room.

Role	Who	What they need to hear
Economic buyer	CISO or VP Security	Insider and session-theft exposure is currently unmeasured. This measures it in a week, without a headcount increase and without an endpoint rollout.
Technical champion	Head of SecOps / Identity Architect	It is agentless, the alerts are explainable, and it will not become a second full-time tuning job like the last one did.
Blockers	Legal, Privacy, works council, Engineering leadership	No content inspection, no keylogging, pseudonymous by default, dual-custody unmasking, nothing installed on developer machines.

The blocker row is the one most startups discover late. In the engineering-led organisations we are targeting, a security tool that monitors developers is vetoed by engineering leadership more often than by legal. tellTale's answer — nothing on your laptop, no code read, no names by default — is designed to be delivered to that audience specifically.

4.2 Ideal customer profile

India-first, global-ready. The product, the pricing and the legal architecture in §3.8 are built for the Indian mid-market as the primary beachhead, and generalise to comparable cloud-first firms elsewhere without modification — the jurisdiction profiles in §3.8.1 exist for exactly that expansion.

Attribute	Target
Geography	India first — Bengaluru, Pune, Hyderabad and the NCR technology corridors, where cloud-first mid-market firms are dense and workforce-analytics budgets are already normalised (§4.4). US and EU cloud-first firms are the secondary beachhead, reachable without re-architecture via the jurisdiction profiles.
Size	500–3,000 employees. Large enough to have valuable IP and an insider risk surface; small enough that the security team cannot operate a legacy SIEM deployment.
Sector	B2B SaaS and FinTech as beachhead. Biotech and healthcare as the expansion tier, where regulatory pressure is higher but sales cycles are longer.
Stack	Okta or Google for identity, Google Workspace, GitHub, AWS, Jira. Explicitly *not* Microsoft-centric — that is where Purview's bundled distribution is strongest and where we should not fight.
Security team	One CISO, one SecOps lead, two or three generalist engineers. No 24/7 SOC. This shape of team is why time-to-value dominates every other purchase criterion.
Compelling event	SOC 2 Type II preparation; the departure of a senior engineer or executive; a session-hijacking incident; a customer security questionnaire they cannot answer honestly.

Disqualifiers	Fully Microsoft-native (Purview is bundled and good enough); under 200 employees (insufficient cohort data and no budget); air-gapped or defence environments (requires certifications we will not hold for years).

4.3 Competitive landscape

Vendor	Genuine strength	Structural weakness	Our position
Microsoft Purview IRM	Bundled with E5; excellent inside Microsoft 365; native sensitivity labels	Weak visibility into GitHub, AWS, non-Microsoft SaaS; sequence rules widely reported as noisy; exclusions do not inherit cleanly	Do not compete inside Microsoft estates. Win the non-Microsoft and developer-heavy stack, where their coverage is thinnest.
Exabeam / LogRhythm	Mature session timelines; strong tier-1 triage ergonomics	Log-ingest architecture; parser fragility; 45–90 day time to value; no operational context	Time to value and context. We are useful in a day; they are useful in a quarter.
Securonix	Scale; broad compliance coverage	Volume-based pricing penalises collecting data; heavy tuning burden	Per-identity pricing. The customer is never punished for having more telemetry.
Varonis	Unmatched understanding of unstructured data permissions	Storage-centric; limited identity lifecycle and developer-tool visibility; premium pricing	Complementary rather than competitive. A credible integration partner.
DTEX	Privacy-respecting metadata endpoint telemetry; defence-grade	Requires an endpoint agent across Windows, macOS and Linux; limited cloud-to-cloud visibility	Agentless. The entire adoption barrier they carry, we do not.
Proofpoint ITM / Teramind	Deep endpoint forensics; screen replay; mature agents	Collection-led rather than detection-led; little operational context; blunt configuration across jurisdictions	Now a direct competitor rather than an opposite. We collect comparable telemetry and add the context gate, the calibrated queue and the jurisdiction profiles they lack.
ActivTrak, Hubstaff, others in the workforce-analytics class	Usage, timesheets, screenshots, productivity reporting; strong in the Indian and SMB mid-market; low price point — typically ₹5,000–₹10,000 per user per year for reporting alone	No detection engine. Anomaly handling is thresholds and manual review; no trajectory model, no context verification, no calibrated prioritisation	We are a superset priced at parity: the Sensor tier is ₹7,000/identity/yr — inside their own range — and includes everything they charge for plus the detection engine they lack. In India this is the most likely displacement path, because the buyer already owns the category and the budget (§4.1, §4.4).
Okta ITP / CrowdStrike Falcon ID	Fast, native, already deployed	Authentication-centric; blind to post-login lateral SaaS trajectory	We start where they stop — after the login succeeds. Partner, do not compete.

4.4 Pricing and packaging

Per monitored identity per year, billed annually, in Indian Rupees as the primary currency for a product whose beachhead is the Indian mid-market (§3.8.2). Not per gigabyte, not per event, not per endpoint.

Tier	Price	Who	Included
Cloud	₹3,000 / yr *₹250/mo*	General business users; the agentless landing tier	Identity and SaaS telemetry, baselines, trajectory scoring, context gating, dossiers, Review Alerts

Sensor	₹7,000 / yr *₹580/mo*	Anyone on a managed corporate device	Adds the endpoint agent: application and window metadata, presence, file and device events, presence divergence and composition drift, plus the full workforce module — Team Overview, App Usage, attendance
Sensor + Capture	₹11,000 / yr *₹920/mo*	Engineers, DevOps, admins, executives, and regulated environments	Adds scheduled and triggered screen capture with the evidence vault, honeytoken orchestration, action path graph and containment webhooks
Non-human identity	₹5,000 / yr *₹420/mo*	Service accounts, CI tokens, AI agents	Same engine, no endpoint plane by definition (see §4.12)
Blended average	₹6,000 / yr *~₹500/mo*	Typical mix: 45% Sensor, 25% Cloud, 20% Capture, 10% NHI	The number used in all modelling below

The tiering is doing commercial work beyond price discrimination. It lets a customer buy the agentless tier in fifteen minutes, prove value, and expand into the Sensor on a separate decision cycle — so the endpoint rollout never blocks the first sale. It also maps cleanly onto the jurisdiction profiles in §3.8.1, which means the EU conversation is a tier conversation rather than a product objection.

Why this model wins on procurement mechanics, not just price. Ingest-volume pricing creates a perverse incentive: the customer reduces security coverage to control cost, and every new data source triggers a budget conversation. Per-identity pricing is predictable, scales with headcount the finance team already forecasts, and makes adding a telemetry source free. Against Microsoft, the comparison is an E5 uplift for organisations that do not otherwise want E5. Against the workforce-analytics incumbents the comparison is exact and worth stating precisely: ActivTrak, Hubstaff and others sit at roughly ₹5,000–₹10,000 per user per year for reporting alone (§4.3), and our Sensor tier lands at ₹7,000 — inside that same range — while including the detection engine none of them has.

BUDGET-LINE REALITY IN THE INDIAN AND SMB MID-MARKET

"Insider threat behavioural transition detection" is not a line item any mid-market Indian company budgets for — §4.1 already establishes that pure detection is sold into ITDR and insider-risk budgets that barely exist below enterprise scale. **Workforce analytics and employee activity monitoring is a budget that already exists**, funded, renewed annually, and owned by an operations or HR-systems lead who is actively comparing vendors on exactly the axes our Sensor tier competes on.

This is why the Sensor tier is priced at incumbent parity rather than at a premium: the sale does not require creating a new budget, only winning a renewal decision inside one that already exists. The detection engine then arrives as an upgrade the buyer did not have to ask for, not as a new procurement category they have to justify.

4.5 Unit economics

Metric	Value	Basis
Average contract value	₹90,00,000 *₹90 Lakh*	*Derived* — 1,500 identities × ₹6,000 blended
Infrastructure cost per identity/yr	₹1,150	*Derived* — §3.5; capture storage dominates, retention policy is the lever
Support and success allocation	₹290	*Estimated* — higher than before: there is now an agent to support across three operating systems
Gross margin	~76%	*Derived* — down from ~87% agentless. Storage and agent support are the whole difference
Customer acquisition cost	₹40,00,000 *₹40 Lakh*	*Estimated* — marginally higher; the Sensor adds a security-review step
CAC payback	~7.0 months	*Derived* at 76% margin on a larger contract — payback improves despite the thinner margin

Target gross retention	90%	*Target* — mid-market security tooling norm
Target net revenue retention	115%	*Target* — headcount growth plus privileged-tier and NHI expansion

Two successive revisions downward, both recorded in Appendix A. The original 91.2% omitted customer support; correcting that gave ~87%. Adding the endpoint plane and screen capture takes it to ~76%, because image storage is three orders of magnitude heavier than the metadata it accompanies and an agent has to be supported. We are trading roughly eleven points of margin for a 50% larger contract, a second budget line, and access to the workforce-analytics market — which we judge worth it, but it is a trade and not a free upgrade. Figures are stated in INR throughout, since the Indian mid-market is the beachhead (§3.8.2); a ₹83/US$1 cross-reference is used only where a figure originates from a USD-denominated source, as in §4.6.

4.6 Market sizing with derivation

Layer	Value	Derivation
TAM	₹1,50,000 Cr *~US$18B*	*Estimated* from published analyst coverage, originally USD-denominated: ITDR (~$9B), cloud insider risk management (~$5B), and data-security behavioural analytics (~$4B). Category boundaries overlap and definitions vary by analyst, so this is a directional figure, not a precise one. Converted at ~₹83/US$1.
SAM	₹35,000 Cr *~US$4.2B*	*Derived* bottom-up: approximately 70,000 organisations globally — including the Indian and global high-IP mid-market — in the 500–10,000 employee band, on cloud identity, × ₹50,00,000 (₹50 Lakh) average contract value.
SOM	~₹390 Cr ARR *~US$48M*	*Derived*: 650 customers over 48 months at ₹60,00,000 (₹60 Lakh) average contract value — roughly 1.1% of SAM. We round this to ₹400 Cr in conversation; the precise derivation is ₹390 Cr.

The SOM's ₹60 Lakh average contract value is deliberately lower than the §4.5 ACV of ₹90 Lakh: the ACV figure models a representative 1,500-identity account, while the SOM blends in a longer tail of smaller mid-market wins across 650 customers. Both are derived, from different and clearly stated bases, and we would rather show that seam than paper over it.

Sensitivity

The SOM is the only number that should influence a decision, so it is worth stating what breaks it. At half our assumed win rate, SOM is ~₹195 Cr — still a viable company. At half the assumed ACV, the sales motion must become self-serve or channel-led, which is a different company. At a third of the assumed SAM (if the non-Microsoft cloud-first mid-market is smaller than believed), the beachhead is too narrow and the correct move is to expand into non-human identities earlier than planned (§4.12). We track the second and third of these as leading indicators, not the first.

4.7 Go-to-market: the 15-minute audit wedge

Enterprise security sales normally run six to nine months because the buyer must be convinced a problem exists before evaluating a solution. Our wedge collapses that by showing them the problem in their own data.

Step 1 — Connect (15 minutes). Read-only OAuth to Okta and GitHub. No agent, no procurement, no engineering ticket. Reversible by the admin at any moment, which is what makes the yes cheap.

▼

Step 2 — Replay (2 hours). Ingest the 90 days of audit history the platforms already retain. Baselines are built from history rather than waiting for it, so there is no learning period.

▼

Step 3 — Report (day 2). An executive brief covering: departing employees whose access patterns changed before they resigned; dormant privileged credentials with anomalous recent activity; sessions whose trajectory crossed platforms in ways nobody authorised; and an estimate of how many of the customer's existing alerts our context layer would have suppressed.

▼

Step 4 — Convert (30–45 days). The conversation is no longer about our technology. It is about specific findings in their environment, which they now cannot un-see.

The strategic property of this motion is that the audit is *also* the product demo, the technical validation, and the security review, collapsed into one artefact. And because it runs on historical logs, it produces findings on day two rather than after a 60-day baselining period — which is the single biggest structural advantage we hold over log-based incumbents.

A CHANNEL WE ACTUALLY HAVE

One of us has direct access to a company operating a production workforce-analytics platform in the Indian mid-market. That is worth more than it first appears, and for three distinct reasons.

It is a **design-partner route**: an existing customer base of Indian mid-market firms already paying for visibility into employee activity, who can be asked what an insider-risk layer would need to look like. It is a **distribution route**: an adjacent, non-competing product sold to the same buyer, where a referral costs nothing and carries real trust. And it is a **grounding route**: access to people who operate monitoring software daily and can tell us which of our assumptions about analyst behaviour are wrong before a customer does.

We are explicit that the products are different — one measures work, the other detects risk, and §1.10.1 records exactly which ideas we took and which we refused. The relationship is a channel and a source of reality-testing, not a shared roadmap.

Concretely, this is a **frictionless upgrade path**: a customer of that platform already runs a Sensor-shaped agent and already owns the workforce budget line described in §4.4. Moving them to tellTale's Sensor tier is a configuration change on infrastructure they have already approved, not a new vendor onboarding — the fastest possible route to the "two budgets, one agent" position in §4.10.

4.8 Marketing and media strategy

Security practitioners have been marketed at by behavioural analytics vendors for a decade and are correspondingly resistant. Conventional demand generation — gated whitepapers, booth traffic, cold sequences — converts poorly against this audience. Our approach inverts it: publish things practitioners find useful whether or not they ever buy, and let the product be the obvious next step.

Channel	Programme	Why it works on this audience
Technical publishing	Detection engineering essays with real mathematics: why rolling baselines lose to slow burn, how to harden context gating, the arithmetic of alert fatigue. Named authors, no gating, no lead capture.	This audience shares rigorous content and blocks marketing content. Depth is the distribution mechanism.
Open-source wedge	Release the trajectory-scoring library and the synthetic enterprise telemetry generator under a permissive licence. Keep the context engine, console and connectors commercial.	Credibility that cannot be bought, plus a genuine contribution — realistic modern insider-threat datasets do not exist publicly, which is a problem for the whole field.

Community presence	Sustained participation in practitioner forums and identity-security communities. Answer questions about the problem, including where our approach is weak, without pitching.	Trust compounds and is nearly impossible for a better-funded competitor to buy.
Conference talks	Submit the adversarial-context-gating work and the evaluation methodology to practitioner security conferences. A talk on how to attack context gating is more interesting than one on how to use it.	Positions us as the people who thought hardest about the failure modes — the strongest available signal of technical seriousness.
The audit as content	Anonymised aggregate findings published quarterly: what fraction of organisations have dormant privileged credentials, how often departing-employee access patterns change, typical alert-suppression rates.	Original data is the most linkable asset a security company can produce, and ours is a by-product of delivery rather than a research cost.
Channel and alliances	Identity platform marketplaces; joint material with identity vendors whose coverage stops at authentication; regional MSSP partnerships for EU expansion.	Borrows distribution and trust from a platform the customer already bought.

Positioning and message

One sentence, used everywhere: **"Your security tools alarm on events. tellTale scores the change in direction — and checks whether your own systems authorised it."** The telltale metaphor is doing real work: the ribbon on a sail is a small early indicator of a change in airflow, which is exactly and non-metaphorically what the product does. Three proof points, in this order every time: *fifteen minutes to first finding*, *every alert arrives with its evidence*, *nothing installed on anyone's laptop*.

Measurement

Vanity metrics are excluded. We track audits booked, audit-to-paid conversion rate, days from first contact to signature, and the proportion of pipeline originating from published content versus outbound. If content-originated pipeline does not exceed outbound by month twelve, the strategy is wrong and we switch to conventional demand generation rather than persisting on principle.

4.9 Scalability and sustainability

Scalability of the business

- **Marginal cost is near zero.** Each additional identity adds a few dollars of infrastructure per year. No agent to distribute, no GPU to provision, no per-seat professional services.
- **Onboarding does not scale with headcount.** Fifteen-minute OAuth setup means account count grows without a proportional implementation team — the constraint that caps most enterprise security companies.
- **Expansion is structural.** Land on identity and GitHub; expand by adding platforms, upgrading users to the privileged tier, and onboarding non-human identities. Every expansion path is a configuration change, not a new sale.
- **Geography is unblocked.** The privacy architecture makes EU expansion a normal sales motion rather than a legal project — a genuine advantage over US-headquartered monitoring vendors.

Sustainability of the business

- **Revenue quality.** Annual contracts, high gross margin, security budgets that are more defensible than most during downturns.
- **The renewal risk is honest.** A detection tool that finds nothing in year one is hard to renew. Our answer is that the audit findings, the suppression log, and the fairness report make the value legible quarterly rather than only after an incident. We would rather solve this with evidence than with a multi-year lock-in.
- **Cost discipline as a design property.** Choosing statistical methods over deep learning removes a large and volatile cost line permanently. That decision was made for explainability and turns out to be a margin decision too.

- **Capital efficiency.** A ₹16–21 Crore seed reaches a commercial v1 and first paying customers. The architecture does not require a research budget to reach revenue.

4.10 Defensibility

Honesty first, and it now cuts twice. **The algorithms are not the moat** — median absolute deviation, Markov transition matrices and logistic regression are textbook, and a competent team could reproduce the detection core in a few weeks. **Nor is agentlessness**, which earlier drafts of this document treated as a primary differentiator. Once we ship an endpoint Sensor we forfeit that claim, and we should say so plainly rather than keep the slogan. What remains is the list below, and it is a better list because none of it is a slogan.

What is actually defensible, in increasing order of durability:

Asset	Why it is hard to copy	Durability
Context integration breadth	Not algorithmically hard, but a long tail of integration work with ticketing, HR, on-call, calendar and code review systems, each with its own semantics of "who assigned this and when".	**Medium — replicable with sustained effort**
Pre-tuned cross-platform transition priors	Aggregate transition statistics across many organisations let a new customer be useful on day one. Accumulates with customer count and cannot be bought.	**High — compounds over time**
Architectural commitment to explainability	A competitor built on deep models cannot retrofit exact attribution. They would have to rebuild the detection core and accept a lower benchmark number to do it.	**High — structural**
Jurisdiction profiles	Not hard to copy in principle, but it requires having decided that one global configuration is wrong — which collection-led vendors have structurally not done. Shipping a draft works agreement with the product is a sales asset none of them carries.	**Medium — a lead, not a lock**
Two budgets, one agent	Workforce analytics and insider risk are bought by different people from different lines, and one Sensor deployment satisfies both without either buyer having to trust the other's vendor. Renewal now requires two independent stakeholders to separately decide to leave. Neither a pure ITDR vendor nor a pure monitoring vendor can do this without building the other half.	**High — structural**
Adversarial hardening of the context layer	Requires having thought about the attack before shipping the feature. Late-arriving competitors ship the naive version and inherit the vulnerability.	**Medium — a lead, not a lock**

TWO BUDGETS, ONE AGENT — WORKED EXAMPLE

	CISO / SecOps lead	HR / Operations lead
Owns	Identity threat and insider-risk budget	Workforce analytics and attendance budget
Gets from the same Sensor	Session-theft detection, credential-misuse alerts, an evidence-backed dossier per finding	Team Overview, App Usage, attendance, screen-capture reporting
Sees	Pseudonymous `#4912`, never a productivity rating (Rule 2, §1.10.2)	Named employees, never a risk score (Rule 2, §1.10.2)
Renewal risk	Both stakeholders must independently decide to leave — losing one budget conversation no longer loses the account.	

The most serious commercial risk is not competition but commoditisation: an identity platform bundling adequate trajectory analysis into a product the customer already owns. The defence is to become the layer that *consumes* identity platform signals and adds the organisational context those platforms do not have and have no obvious path to acquiring. Partnering with identity vendors rather than competing with them is a deliberate strategic choice, and §4.12 is the second answer to the same question.

4.11 24-month roadmap

Phase	Technical	Commercial
Months 1–6 Foundation	Okta, Google Workspace, GitHub connectors; context integration for ticketing and HR; detection core hardened; honeytoken orchestration	Five design partners; retrospective audits on real historical logs; first measured false-positive reduction against real telemetry
Months 7–12 Commercial v1	Investigation console; containment webhooks with human approval; AWS CloudTrail ingest; multi-tenant isolation; **endpoint Sensor for Windows and macOS** with the workforce module and jurisdiction profiles	SOC 2 Type II; first paid contracts; publish open-source trajectory library and telemetry generator
Months 13–18 Enterprise	Graph topology engine; HSM-backed dual custody; cross-tenant transition priors; fairness auditing as a customer-facing report; Linux Sensor; scheduled and triggered capture with the encrypted evidence vault	EU expansion with works-council documentation; identity marketplace listing; channel partnerships
Months 19–24 Expansion	Non-human identity and AI agent profiling; risk-adaptive policy signals to access control; sequence models where federated data now justifies them	Growth financing; move upmarket; NHI as a distinct product line

4.12 The non-human identity expansion

This is the answer to "why is this a company rather than a feature", and it required no architectural change because §1.4 made the unit of analysis the credential rather than the person.

Enterprises now run large and growing populations of non-human identities: service accounts, CI/CD tokens, API keys, and increasingly autonomous agents holding real privilege. From a detection standpoint these are *easier* than humans — more repetitive, more predictable, narrower in scope. A Markov model fits an agent's action sequence more tightly than a person's, because agents genuinely do the same things in the same order.

The threat model is also distinct in a way that favours our approach. An AI agent subverted through prompt injection or tool misuse does not break authentication. It holds valid credentials and calls authorised tools in an unauthorised sequence. Every identity-layer control passes. Every endpoint control passes. **The only observable is the trajectory** — which is the thing we already score.

WHY THIS MATTERS STRATEGICALLY

An agent that normally reads fifteen files and opens a pull request, and then queries a customer database and posts to an external endpoint, has produced exactly the transition signature we built the engine to detect. The same code path, the same explanation format, the same dossier.

Commercially this is the strongest answer to the commoditisation risk in §4.10. If an identity platform bundles human behavioural analytics, the non-human identity population is growing faster, is worse served, and is harder for an authentication-centric vendor to reach — because they see the agent log in, and nothing after. It also removes the dependency on headcount growth for expansion revenue, which is the weakest assumption in the §4.5 net-retention target.

4.13 What would have to be true

Four conditions, stated as falsifiable propositions rather than ambitions. If any one of them turns out to be false, this is a useful product but not a large company, and we would rather know which.

1. **Context data is real and reachable.** Mid-market organisations must actually use ticketing and HR systems consistently enough that authorisation records exist to verify against. Where process is informal, our central differentiator degrades to a nice-to-have. *Testable in the first five design-partner audits*, by measuring what fraction of anomalous activity has any corresponding record at all.
2. **Buyers will pay for suppression, not only detection.** Security budgets historically reward finding more, not finding less. We are asking a buyer to pay for a quieter queue. *Testable at first contract* — if deals close on audit findings rather than on false-positive reduction, the positioning is wrong even if the technology is right.
3. **The product becomes a control plane, not a scoring API.** A detector that only emits scores gets absorbed as a feature of whatever platform owns the workflow. Owning the investigation and the containment decision is what keeps it a product. *Testable by month 18* — whether customers work inside our console or export our scores into someone else's.
4. **Non-human identities arrive as expected.** The §4.12 expansion assumes agent and service-account populations keep growing and stay poorly served. *Testable continuously*, and it is the condition we have least control over.
5. **The two modules stay separable.** Shipping workforce analytics alongside insider risk is a bet that the combination sells better than either alone without the security product being dismissed as surveillance by the buyers who care about that distinction. *Testable in the first ten sales conversations* — if security buyers treat the workforce module as disqualifying, the Forensic-only profile becomes the default and the workforce module becomes a separate product with a separate name.

APPENDICES

Supporting Material

Appendix A — Corrections register

Material changes made to our earlier research during the preparation of this document, with reasoning. We include this because a reviewer should be able to see what we stress-tested and what we found.

Earlier position	Problem	Correction
0.942 AUROC validated on CMU CERT	Not run. The same documents correctly assess CERT as unsuitable for a cloud/SaaS system.	Removed. Replaced with the evaluation protocol in §2.10, reporting alerts-per-analyst-day at fixed recall against a naive control.
Ticket present → multiply risk by 0.15	Directly exploitable. An insider files a ticket and suppresses their own detection.	Four-test verification — precedence, provenance, scope, proportionality — plus a detector for the manufacturing attempt (§1.7, §2.6).
Markov order stated inconsistently across documents	First-order cannot see ordering; second-order is hopelessly sparse at our data volume.	Order-2 with backoff through user, cohort and population levels, with smoothing and time decay (§2.4).
"14-day baseline period" for new identities	Leaves new joiners undefended during the highest-risk window and generates alert storms.	Hierarchical shrinkage toward cohort, active from day one (§2.3).
Fusion coefficients stated without origin	Unfalsifiable magic numbers.	Fitted by maximum likelihood with monotonicity constraints, or explicitly tagged as priors; provenance recorded per coefficient (§2.7).
"85% false positive reduction"	No denominator — reduction against what?	Explicit naive control detector implemented and run over identical data (§2.10).
Score presented as calibrated without a calibration step	A logistic output is not automatically a probability; prioritisation by expected cost requires it to be.	Isotonic calibration on a held-out split; reliability diagram and Brier score reported (§2.7).
Dossier displaying a named employee	Contradicts the pseudonymisation architecture in the same document.	All artefacts pseudonymous; unmasking shown as an explicit dual-custody step (§2.12).
Kafka + ClickHouse + Redis + Postgres	Four stateful services for a workload one handles.	PostgreSQL only, with a written, measurable migration trigger (§2.9).
Gross margin 91.2%	Excluded customer support entirely.	Revised to ~87% including support allocation (§4.5).
LLM-generated investigation dossiers	A hallucinated fact in the evidence artefact destroys the product's central claim.	Deterministic templates; language model restricted to smoothing one summary sentence, with fallback (§1.9).
"Flatly illegal under German works council co-determination"; screen capture rejected on legal grounds	Overstated. BetrVG s.87(1) No. 6 confers co-determination — a required negotiation — not a prohibition. Screen capture is lawful on corporate devices across most of our market.	Rewritten as a negotiation and proportionality question. Screen capture now declined on architectural grounds (§1.5.1), with triggered forensic capture offered as an enterprise module.

Keystroke dynamics "classified as biometric data under GDPR Art. 9 and the India DPDP Act 2023"	False for the Indian half. The DPDP Act has no special-category regime; all digital personal data is treated alike.	Corrected to GDPR only. The Indian objection to keystroke dynamics is restated as signal quality rather than law (§1.5, §3.8.1).
India treated as a compliance obstacle alongside GDPR	Backwards. DPDP s.7(i) names espionage and trade-secret protection as legitimate uses requiring no consent, with no balancing test.	New §3.8.1 treats India as the most permissive of the three regimes and a viable second beachhead, with the commencement timeline as a selling window.
Console surfaces specified without reference to prior art	A production workforce-analytics platform had solved the investigation IA better than our spec did.	New §1.10.1 records what we adapted (composite timeline, heartbeat, flagged evidence, filter triple, export) and what we refused (productivity scoring, idle time, fixed-interval capture), with reasons.
All commercial figures denominated in USD; India treated as one target market among several	The beachhead is Indian mid-market cloud-first firms (§4.2), and INR is the currency that budget conversation actually happens in.	Pricing, unit economics and market sizing converted to INR throughout Part 4, at a stated ~₹83/US$1 cross-reference for figures sourced from USD-denominated analyst coverage (§4.6).
Console surfaces described at the architecture level only, with no shipped terminology or detailed workforce screens	The build now exists. Engineering names ("investigation queue", "expected cost of inaction") are not how an analyst or a workforce admin talks.	§1.10 renames every surface into its shipped console label; §1.10.2 documents the four workforce screens — Team Overview, App Usage, Screen Captures, Member Profile — and the three governance invariants by name.
Console described as a single visual theme with no stated ergonomics	A 24/7 SOC desk has different needs from a daytime executive review, and search/sort/navigation behaviour across tables was unspecified.	New §2.9.1 specifies the dual-theme token set, instant search and multi-column sort, and the collapsible navigation rail.
Endpoint collection excluded; "agentless" treated as a core differentiator and a moat	Lawful on corporate devices across the target market, and an API-only design is structurally blind to local files, internal tools and legacy applications.	Optional endpoint Sensor added (§2.5.1), enabling two further detectors — presence divergence and composition drift. Agentless is now the default landing tier, not a claim about what we refuse.
Application usage rejected alongside productivity scoring	Conflated two different things. Application and window metadata is resource-level trajectory telemetry, not a productivity metric, and it feeds the Markov model directly as additional tokens.	Usage collection added as core Sensor telemetry (§1.5). Productivity *classification* remains excluded from the risk model, while category *composition* is now a detector.
Screen capture as an optional V2 module only	Understated demand. Scheduled capture is a primary purchase driver in the Indian mid-market and the workforce-analytics category generally.	Two capture modes shipped and separated: scheduled for the workforce module, triggered for forensic corroboration, both gated by jurisdiction profile (§1.5.1, §3.8.1).
"tellTale collects no signal that would support productivity measurement"	**No longer true** once the workforce module ships. The strongest privacy guarantee in the document was architectural, and the architecture changed.	Replaced in §3.7 with an explicit governance guarantee — feature-boundary exclusion, separate role grants, audited crossings — and an acknowledgement that a determined customer can now misuse the product in a way they previously could not.
Gross margin ~87%; blended price $48; ACV $72k	All three assumed a metadata-only cloud product.	Revised to ~76% margin, $72 blended, $108k ACV (§4.5). Capture storage and agent support account for the entire margin difference.

Product name "AegisContext"	Follows a recognisable generated-naming pattern; says nothing about what the product does.	**tellTale** — plain English, dual meaning, both readings on-topic.

Appendix B — Glossary

Term	Plain English
SIEM	A very large searchable store of logs from across the company. Good at keeping records, not at judgement.
UEBA	Software that counts what users do and flags anything above average. The generation of tools this problem statement exists because of.
ITDR	Security focused on identities: logins, permissions, session tokens. The budget line we sell into.
EDR	Software inside the laptop watching for malware. Blind to a legitimate user making legitimate cloud API calls.
Living off the land	Attacking with the tools already installed and permitted. Nothing malicious to detect — only the pattern of use is wrong.
Session token	The credential issued after login that grants access without re-authenticating. Steal it and you skip every login control.
MAD	Median absolute deviation. A measure of spread that one extreme day cannot distort, unlike standard deviation.
Markov model	Counting how often action B follows action A, then scoring how surprising an observed sequence is. No training, no GPU, fully inspectable.
Surprisal / perplexity	How improbable a sequence was under the model. High surprisal means "this path is close to unprecedented here".
Calibration	Making a score mean what it says: among events scored 0.8, about 80% should actually be malicious.
Honeytoken	A fake credential or document placed where only someone looking for it would find it. Touching it is almost never innocent.
Baseline poisoning	Escalating slowly so the system's idea of "normal" moves with you. Also called the boiling-frog attack.
Works council	An employee representative body with legal co-determination rights over workplace monitoring in several European countries. A real veto, not a formality.
Non-human identity	A credential belonging to a machine, service or AI agent rather than a person. Increasingly the majority of identities in an enterprise.

Appendix C — Evaluation results template

Recorded here when the evaluation run completes, under the protocol in §2.10. We publish the table whatever it says.

Metric	Naive control	tellTale	Notes
Recall on seen attack families	—	—	Fixed at 0.90 for the comparison
Recall on held-out family	—	—	Generalisation; expected lower
Alerts / analyst / day at 0.90 recall	—	—	**Primary metric**
Precision@10	—	—	Top of queue
Median time-to-detection, slow burn	—	—	From first malicious action
Suppression precision	n/a	—	Fraction of gated alerts genuinely benign

Brier score	—	—	Calibration quality
Evasion: baseline poisoning	—	—	Adaptive attacker
Evasion: manufactured context	n/a	—	Adaptive attacker
Fairness: max cohort alert-rate ratio	—	—	Disproportionality audit (§3.7)

Appendix D — Evidence base and sourcing discipline

Claims in this document rest on four classes of source, and we distinguish them because they carry different weight.

- **Primary vendor documentation** — published product and API documentation for the identity, SaaS and security platforms discussed. Used for capability claims, connector feasibility and licensing structure. Highest reliability for what a product does; lowest for how well it works.
- **Practitioner reporting** — public discussion among security engineers and peer review platforms, used for operational complaints such as tuning burden, connector fragility and alert fatigue. Directionally reliable and consistent across sources, but self-selected toward dissatisfaction. We treat it as evidence that problems exist, not as a measurement of their frequency.
- **Analyst market coverage** — industry market sizing and category definitions. Used only for TAM-level figures, which we label *estimated* throughout; category boundaries differ between analysts and the overlaps are real.
- **Regulatory and standards text** — GDPR, the India DPDP Act 2023, German works-council law, NIST SP 800-207 and OCSF schema definitions. Primary text, used directly for the compliance positions in §3.8.

Where we could not verify a figure to our own satisfaction, it is labelled *estimated* or omitted. Appendix A records every case where this discipline forced us to remove or revise a claim we had previously made. We regard that list as the most useful page in the document.

CLOSING POSITION

Our problem statement asks for early detection of dangerous behavioural transitions while controlling false positives. Those two objectives are in direct tension, and every deployed system we examined resolves the tension by sacrificing one — usually by becoming so noisy that it is quietly switched off.

tellTale's position is that the tension is resolvable, but not inside the security telemetry alone. The information that distinguishes a promotion from a theft does not live in the logs. It lives in the ticket that was assigned yesterday, the on-call rotation, the resignation filed last week — and in whether those records were created by someone other than the person they now excuse. Reading that context, verifying it against attack, and showing the analyst exactly how it was weighed is what the product is.

The ribbon on the sail does not tell you there is wind. It tells you the direction changed, early enough to do something about it.